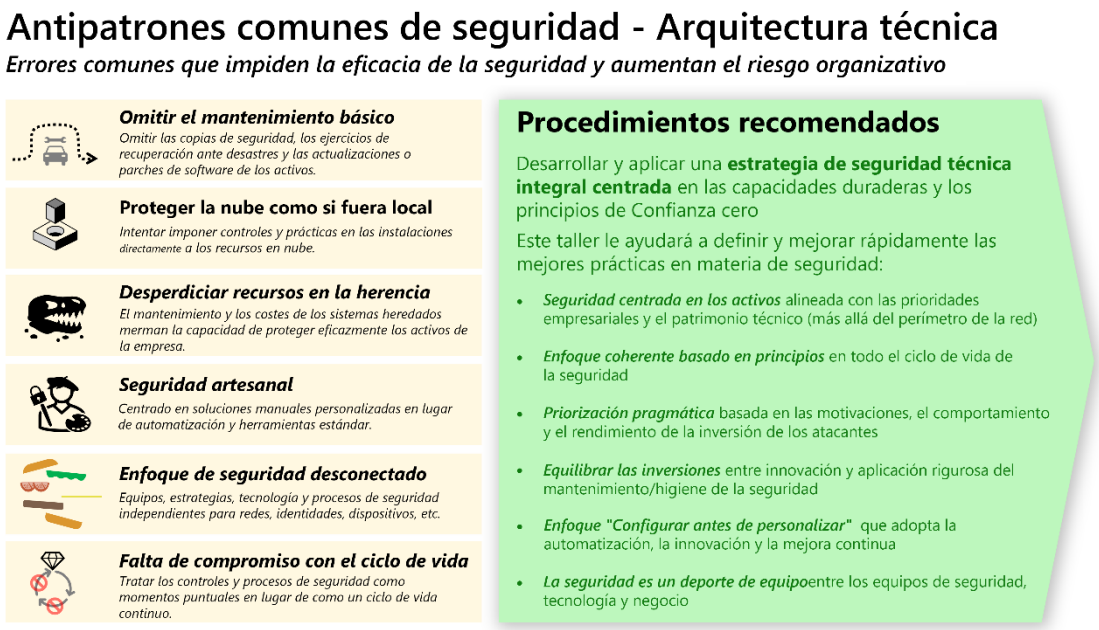
Diseño de soluciones que se alineen con los procedimientos recomendados de seguridad y las prioridades

Las mejores prácticas son abordajes recomendados que se han encontrado que son más eficaces o eficientes. Ayudan a evitar errores y a garantizar que los recursos y el esfuerzo no se desperdician.

Los procedimientos recomendados vienen en muchas formas:

- Instrucciones exactas sobre qué hacer, por qué hacerlo, quién debe hacerlo y cómo hacerlo.
- Principios generales para guiar diferentes tipos de decisiones y acciones.
- Instrucciones que forman parte de una arquitectura de referencia, que describen los componentes que se deben incluir en una solución y cómo integrarlos juntos.

Un **antipatrón** es un error común que conduce a resultados negativos. Es lo contrario de un procedimiento recomendado. Muchos procedimientos recomendados están diseñados específicamente para ayudarle a evitar antipatrones.



Confianza cero es una estrategia de seguridad. No es un producto ni un servicio, sino un enfoque para diseñar e implementar la seguridad. Zero Trust

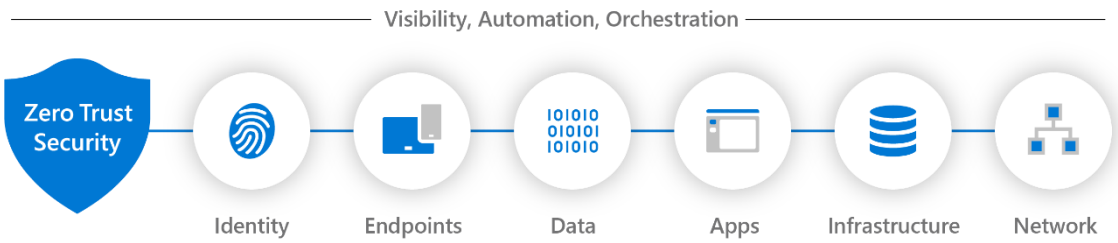
asume la vulneración y comprueba cada solicitud como si se origina en una red no controlada. Independientemente de dónde se origine una solicitud o a qué recurso accede, Confianza cero le enseña a "nunca confiar, comprobar siempre".

Confianza cero se basa en **tres** principios:

- **Compruebe explícitamente:** Autentíquese y autorice siempre en función de todos los puntos de datos disponibles, incluida la identidad del usuario, la ubicación, el estado del dispositivo, el servicio o la carga de trabajo, la clasificación de datos y las anomalías.
- **Utilice el acceso de menor privilegio:** Limite el acceso de los usuarios mediante acceso justo a tiempo y justo lo suficiente (JIT/JEA), políticas adaptativas basadas en riesgos y protección de datos. Esto limita el radio del impacto un posible incumplimiento, de modo que si una cuenta se ve comprometida, se contiene el posible daño.
- **Asumir brecha:** minimice el radio de explosión y segmente el acceso. Compruebe el cifrado de un extremo a otro y use análisis para obtener visibilidad, impulsar la detección de amenazas y mejorar las defensas. Este principio supone que un atacante obtendrá acceso a una cuenta, un punto de conexión, una aplicación u otro recurso y protege en consecuencia.

Seis pilares tecnológicos

Pilar tecnológico	Description
Identidades	Las identidades, tanto si representan personas, servicios o dispositivos IoT, definen el plano de control Confianza cero. Cuando una identidad intenta acceder a un recurso, verifique la identidad mediante autenticación fuerte y asegúrese de que el acceso cumple con las normativas y es habitual. Siga los principios de acceso con privilegios mínimos.
Puntos finales	Una vez que se ha concedido acceso a una identidad, los datos pueden fluir a distintos puntos de conexión (dispositivos), desde dispositivos IoT a smartphones, traer su propio dispositivo (BYOD) a dispositivos administrados por asociados y cargas de trabajo locales a servidores hospedados en la nube. Esta diversidad crea una gran superficie expuesta a ataques. Supervisa y aplica el estado y el cumplimiento del dispositivo para un acceso seguro.
Datos	En última instancia, los equipos de seguridad protegen los datos. Siempre que sea posible, los datos deben permanecer seguros incluso si abandonan los dispositivos, las aplicaciones, la infraestructura y las redes que controla la organización. Clasifique, etiquete y cifre los datos y restrinja el acceso en función de esos atributos.
Aplicaciones	Las aplicaciones y las API proporcionan la interfaz por la que se consumen los datos. Aplique controles y tecnologías para descubrir TI en la sombra, asegúrese de que los permisos dentro de la aplicación sean adecuados, controle el acceso basándose en análisis en tiempo real, monitoree el comportamiento anómalo y valide las opciones de configuración seguras.
Infraestructura	La infraestructura(ya sea servidores locales, máquinas virtuales, contenedores o microservicios basados en la nube) representa un vector de amenazas crítico. Evalúe la versión, la configuración y el acceso JIT para fortalecer la defensa. Use la telemetría para detectar ataques y anomalías, y bloquear y marcar automáticamente el comportamiento de riesgo.
Network	En última instancia, se accede a todos los datos a través de la infraestructura de red. Los controles de red pueden proporcionar visibilidad crítica y ayudar a evitar que los atacantes se muevan lateralmente. Segmente las redes, implemente la protección contra amenazas en tiempo real, el cifrado de un extremo a otro, la supervisión y el análisis.



Microsoft Cloud Adoption Framework (CAF) es una hoja de ruta estructurada que ayuda a las organizaciones a adoptar Azure correctamente e integrarla en sus entornos de TI existentes. CAF proporciona procedimientos

recomendados e instrucciones a lo largo de todo el ciclo de vida de adopción de la nube. CAF organiza instrucciones en siete metodologías principales: **Estrategia**, **Plan**, **Listo**, **Adopción**, **Gobernanza**, **Seguro** y **Administración**.

Azure Well-Architected Framework (WAF) es un marco de diseño que mejora la calidad de una carga de trabajo. WAF le ayuda a diseñar cargas de trabajo resistentes, seguras, optimizadas para costos, excelentes y eficientes de forma operativa.

WAF se basa en **cinco** pilares de excelencia arquitectónica:

- **Confiabilidad:** Garantiza que las cargas de trabajo sean resistentes, disponibles y recuperables.
- **Seguridad:** Protege las cargas de trabajo contra amenazas.
- **Optimización de costos:** Garantiza que las cargas de trabajo ofrecen una rentabilidad suficiente sobre la inversión.
- **Excelencia operativa:** Apoya el desarrollo y las operaciones responsables.
- **Eficiencia del rendimiento:** Garantiza que las cargas de trabajo logren su propósito en períodos de tiempo aceptables.

Las arquitecturas de referencia de ciberseguridad de Microsoft (MCRA) son arquitecturas técnicas que permiten adoptar la seguridad de un extremo a otro mediante principios de confianza cero.

MCRA es un componente del Marco de adopción de seguridad (SAF) de Microsoft e incluye:

- Antipatrones (errores comunes) y procedimientos recomendados.
- Guía para adoptar correctamente un enfoque de seguridad de un extremo a otro mediante principios de confianza cero.
- Diagramas detallados para las funcionalidades de ciberseguridad de Microsoft, acceso de usuario de Confianza cero, operaciones de seguridad, tecnología operativa, funcionalidades multinube, etc.
- Asignación de funcionalidades de Microsoft a los estándares de confianza cero y a los roles de la organización.

El marco de adopción de Confianza cero ayuda a las organizaciones a planear y ejecutar una estrategia de confianza cero en todo su patrimonio digital. Adapta las fases del ciclo de vida del Cloud Adoption Framework para Azure, pero con un alcance adecuado para Zero Trust.

El marco de adopción de Confianza cero usa estas fases de ciclo de vida:

Phase	Description
Definición de la estrategia	Cree un caso empresarial centrado en los resultados más estrechamente alineados con los riesgos y objetivos estratégicos de su organización.
Plan	Priorice los resultados rápidos y el progreso incremental. Estructurar iniciativas coherentes con resultados claros, ventajas y propiedad.
Ready	Cree una estrategia multicapa para la implementación de Confianza cero y priorice las acciones tempranas en función de las necesidades empresariales.
Adoptar	Implemente incrementalmente la estrategia en las áreas funcionales.
Govern	Realice un seguimiento y mida el éxito de la implementación.
Administrar	Use tecnologías de supervisión y detección. Madura cada área funcional de forma incremental.

El Plan de modernización rápida de confianza cero (RaMP) proporciona un conjunto de rutas de implementación para implementar rápidamente capas clave de protección. RaMP toma un enfoque de administración de proyectos y lista de comprobación. Proporciona una asignación sugerida de las partes interesadas clave, los implementadores y sus responsabilidades, junto con listas de comprobación de los objetivos de implementación y los pasos de implementación.

Todos estos marcos comparten Confianza cero como filosofía de seguridad fundamental, pero funcionan en distintos niveles:

- **CAF** funciona a **nivel organizativo**. Guía todo el recorrido de adopción de la nube desde la estrategia hasta las operaciones, incluida la seguridad como una de sus siete metodologías. CAF le ayuda a decidir *cómo adoptar la nube* de forma segura.
- **WAF** funciona en el **nivel de carga de trabajo**. Le ayuda a diseñar y mejorar las cargas de trabajo individuales en cinco pilares de calidad, uno de los cuales es la seguridad. WAF le ayuda *a decidir cómo crear y operar cargas de trabajo* de forma segura.
- **MCRA** funciona en el **nivel de arquitectura**. Proporciona diagramas de referencia y procedimientos recomendados para la seguridad de un extremo a otro en todo el patrimonio de la tecnología híbrida. MCRA le ayuda a decidir *cómo debería ser su arquitectura de seguridad*.
- **MCSB** funciona en el **nivel de control**. Proporciona controles de seguridad prescriptivos organizados en dominios, asignados a estándares de cumplimiento. MCSB le ayuda a decidir *qué controles específicos implementar y supervisar*.

- **El marco de adopción de confianza cero** funciona en el **nivel de estrategia**. Proporciona un enfoque controlado por fases para implementar confianza cero en toda la organización. Le ayuda a decidir *cómo planear y ejecutar la transformación Confianza cero*.

Marco de referencia	Cuándo usar	Audiencia principal
CAF	Cuando quiera crear e implementar estrategias empresariales y tecnológicas para la adopción de la nube.	Arquitectos en la nube, profesionales de TI, responsables de la toma de decisiones empresariales
WAF	Cuando quiera mejorar la calidad de una carga de trabajo en la nube específica.	Arquitectos en la nube, profesionales de TI
MCRA	Cuando necesite una plantilla de inicio para la arquitectura de seguridad, una referencia de comparación o necesite obtener información sobre las funcionalidades de ciberseguridad de Microsoft.	Arquitectos en la nube, profesionales de TI
MCSB	Cuando necesite instrucciones sobre cómo implementar controles de seguridad específicos y supervisar el cumplimiento de los estándares del sector.	Arquitectos en la nube, profesionales de TI
Marco de adopción de Zero Trust	Cuando desee un enfoque por fases orientado al negocio para implementar Zero Trust, desde la estrategia hasta la gestión.	Arquitectos de seguridad, equipos de TI, administradores de proyectos
Zero Trust RaMP	Cuando quieras empezar con Zero Trust y avanzar rápidamente priorizando las áreas de mayor impacto.	Arquitectos en la nube, profesionales de TI, responsables de la toma de decisiones empresariales

- **Exclusión de decisiones**: los equipos empresariales y de TI omiten la participación en la seguridad para mantener la velocidad, dejando brechas de seguridad en las implementaciones en la nube.
- **Puntos ciegos**: las herramientas heredadas diseñadas para entornos locales no pueden detectar patrones de ataque nativos de la nube ni proteger identidades entre sistemas distribuidos.

Una estrategia de seguridad moderna adopta el modelo de responsabilidad compartida, desplaza el foco de los perímetros de red a los controles basados en identidades y usa herramientas nativas de la nube para la detección y respuesta.

Como arquitecto de seguridad, la estrategia de seguridad en la nube debe abordar dos objetivos complementarios:

Objective	Enfoque	Example
Seguridad de la nube	Protección de los recursos en la nube	Integración de la seguridad en el planeamiento y las operaciones del servicio en la nube
Seguridad desde la nube	Uso de la nube para mejorar la seguridad	Adopción de herramientas de seguridad nativas de la nube como Microsoft Sentinel y Defender for Cloud

Definir una estrategia de seguridad es esencial, pero la ejecución de esa estrategia requiere una guía estructurada. Microsoft proporciona dos marcos que convierten la intención estratégica en decisiones arquitectónicas:

- **Cloud Adoption Framework (CAF):** guía el recorrido de adopción de la nube de la organización, con la metodología de seguridad que aborda la seguridad en cada fase.
- **Well-Architected Framework (WAF):** proporciona principios de diseño para crear cargas de trabajo seguras y confiables.

Microsoft Cloud Adoption Framework para Azure es un marco de ciclo de vida completo, que permite que los arquitectos de la nube, los profesionales de TI y los responsables de la toma de decisiones empresariales logren sus objetivos de adopción de la nube. Proporciona procedimientos recomendados, documentación y herramientas que le ayudan a crear e implementar estrategias empresariales y tecnológicas para la nube.

Cloud Adoption Framework consta de estas metodologías diferentes:

- **Estrategia**: alinee las iniciativas de adopción de la nube con objetivos empresariales medibles y objetivos de ROI.
- **Plan**: cree un plan integral alineado con las partes interesadas para la transformación en la nube.
- **Listo**: implemente entornos de Azure listos para la empresa que se escalan de forma segura.
- **Adopte**: Implementar cargas de trabajo de producción en Azure que proporcionen valor empresarial.
- **Controlar**: mantenga el control empresarial, el cumplimiento y la optimización de costos.
- **Seguro**: proteja las cargas de trabajo contra amenazas cibernéticas y vulnerabilidades en constante evolución.
- **Administrar**: garantice la excelencia operativa y la optimización continua.

La seguridad en la nube es un recorrido continuo del progreso incremental y la madurez, no de un destino estático. La metodología segura abarca todas las fases de CAF: **Estrategia, Plan, Listo, Adopción, Gobernanza y Administración**, lo que garantiza que las consideraciones de seguridad informen las decisiones en cada fase.

La metodología segura no es una fase independiente; es una superposición que se aplica a cada paso del recorrido de la nube. Las brechas en cualquier fase debilitan la posición general de seguridad. A medida que usted trabaje en cada fase de CAF, debe abordar la seguridad en paralelo:

- **Estrategia**: definir objetivos de seguridad alineados con los objetivos empresariales
- **Plan**: Desarrollo de requisitos de seguridad e identificación de brechas de aptitudes
- **Listo**: Preparar zonas de aterrizaje seguras y establecer líneas base de seguridad
- **Adopción**: Implementación de controles de seguridad durante la migración e innovación
- **Controlar**: aplicar directivas de seguridad y mantener el cumplimiento
- **Administrar**: operar la supervisión de la seguridad, responder a incidentes y mantener la posición

La metodología segura organiza las actividades de seguridad en torno a dos marcos complementarios**: los principios de triad** y **confianza cero de la CIA.**

CIA Triad

La CIA Triad proporciona un modelo completo para la protección de la información. Debe asignar controles, procesos, telemetría y métricas explícitamente a cada principio:

- **Confidencialidad**: restringe el acceso a datos confidenciales a través del cifrado, la administración de claves, los controles de identidad, las directivas de acceso, la segmentación de red y la clasificación de datos.

- **Integridad**: conserva la exactitud y la integridad de los datos mediante hash, firma, patrones de almacenamiento inmutables, control de versiones y cadenas de suministro de actualizaciones seguras.
- **Disponibilidad**: mantiene el acceso oportuno a los servicios y los datos mediante el diseño de redundancia, el aislamiento de dominio de error, el escalado automático, los sondeos de estado, la copia de seguridad y la recuperación ante desastres.

Confianza cero

Todas las actividades de seguridad deben seguir los principios de confianza cero:

- **Comprobar explícitamente**: autentíquese y autorice siempre en función de todos los puntos de datos disponibles: identidad de usuario, ubicación, estado del dispositivo, servicio o carga de trabajo, clasificación de datos y anomalías.
- **Utilice acceso con privilegios mínimos**: limite el riesgo con acceso Just-In-Time y Just-Enough-Access (JIT/JEA), políticas adaptables basadas en riesgos y protección de datos.
- **Asumir vulneración**: minimice el radio de explosión y el acceso a segmentos. Compruebe el cifrado de un extremo a otro y use análisis para impulsar la detección de amenazas y mejorar las defensas.

La modernización de la posición de seguridad implica elevar continuamente las defensas, las detecciones y las funcionalidades de resistencia. Los controles estáticos se degradan rápidamente frente a las técnicas de atacante en evolución. Alinear el trabajo de modernización con el marco de adopción de Confianza Cero y enriquecer cada fase con mejoras de Confianza Cero.

La preparación y respuesta de incidentes forman una capa de control principal que limita el tiempo de permanencia del atacante y la interrupción empresarial. Incluso los controles preventivos maduros no pueden eliminar los intentos de intrusión. Implemente y mejore continuamente un ciclo de vida de incidentes de un extremo a otro que abarque:

- Disposición y preparación
- Detección y clasificación
- Contención y erradicación
- Recuperación
- Aprendizaje posterior al incidente

La seguridad es una materia humana que requiere roles y responsabilidades claros. La metodología segura identifica las funciones clave:

- **Proveedor de servicios en la nube**: responsabilidad compartida de la seguridad de la plataforma subyacente
- **Equipos de infraestructura y plataforma**: arquitectura, ingeniería y operaciones de recursos en la nube
- **Arquitectura e ingeniería de** seguridad: Diseño de controles de seguridad y administración de posturas
- **Operaciones de seguridad (SecOps/SOC):** Supervisión, detección, respuesta y recuperación de incidentes
- **Gobernanza, riesgo y cumplimiento de la seguridad (GRC):** cumplimiento de directivas, administración de riesgos y cumplimiento normativo
- **Educación y concienciación de la seguridad**: formación y comunicación de directivas en toda la organización

Entre las principales actividades de seguridad de inteligencia artificial en las fases de CAF se incluyen las siguientes:

- **Estrategia**: Definición de los objetivos de seguridad de la inteligencia artificial y los principios de inteligencia artificial responsable
- **Plan**: Evaluar brechas en habilidades de inteligencia artificial y planificar controles de seguridad específicos para la inteligencia artificial
- **Listo: Preparación** de la infraestructura de inteligencia artificial segura y establecimiento de líneas base de seguridad de inteligencia artificial
- **Adopción**: Implementación de controles de seguridad de inteligencia artificial durante la implementación del modelo
- **Gobernanza**: Establecimiento de directivas de gobernanza de inteligencia artificial y administración de riesgos

- **Administrar**: Supervisión de sistemas de inteligencia artificial para amenazas y mantenimiento de la posición de seguridad de la inteligencia artificial

El marco de inteligencia artificial responsable de Microsoft proporciona principios que admiten la implementación segura de inteligencia artificial:

- **Equidad**: asegurarse de que los sistemas de inteligencia artificial tratan a todas las personas de forma justa
- **Confiabilidad y seguridad**: los sistemas de inteligencia artificial deben funcionar de forma confiable y segura
- **Privacidad y seguridad**: los sistemas de inteligencia artificial deben ser seguros y respetar la privacidad
- **Inclusión**: los sistemas de inteligencia artificial deben capacitar a todos los usuarios e interactuar con las personas
- **Transparencia**: los sistemas de inteligencia artificial deben ser comprensibles
- **Responsabilidad**: las personas deben ser responsables de los sistemas de inteligencia artificial

Una zona de aterrizaje de Azure es la salida de un entorno de Azure de varias suscripciones que tiene en cuenta la escala, la gobernanza de la seguridad, las redes y la identidad. Una zona de aterrizaje de Azure permite la migración, modernización e innovación de aplicaciones a escala empresarial en Azure.

- **Escalable:** Todas las zonas de aterrizaje de Azure admiten la adopción de la nube a escala proporcionando entornos repetibles, con una configuración y controles coherentes, independientemente de las cargas de trabajo o los recursos de Azure implementados en cada instancia de zona de aterrizaje.
- **Modular:** Todas las zonas de aterrizaje de Azure proporcionan un enfoque extensible para crear su entorno, en función de un conjunto común de áreas de diseño. La extensibilidad de una zona de aterrizaje de Azure permite a una organización escalar fácilmente elementos específicos del entorno, a medida que evolucionan los requisitos.

Hay **dos** tipos de zonas de aterrizaje:

- **Zonas de aterrizaje de plataforma:** Suscripciones implementadas para proporcionar servicios centralizados, a menudo operados por un equipo central o varios equipos centrales divididos por función, que serán utilizados por diversas cargas de trabajo y aplicaciones. Las zonas de aterrizaje de la plataforma representan servicios clave que a menudo se benefician de la consolidación de la eficacia y facilidad de las operaciones.
- **Zonas de aterrizaje de la aplicación:** Una o varias suscripciones implementadas como entorno para una aplicación o carga de trabajo. Las zonas de aterrizaje de aplicaciones se colocan en grupos de administración como "corp" o "online" debajo del grupo de administración "zonas de aterrizaje" para asegurarse de que los controles de directivas se aplican correctamente.

La seguridad es una de las varias áreas de diseño que definen la arquitectura de la zona de aterrizaje.

Área de diseño	Intersección de seguridad
Identidad y acceso	Base de autenticación, administración de acceso con privilegios, definiciones de roles
Topología de red	Límites de segmentación, puntos de inspección de tráfico, controles perimetrales
Organización de recursos	Ámbito de política, límites de cumplimiento, agregación de auditoría
Gobernanza	Cumplimiento de directivas, supervisión de cumplimiento, detección de desfase

La identidad forma el perímetro de seguridad principal en entornos en la nube. Entre las decisiones de diseño se incluyen:

- **Estrategia de autenticación**: ¿Cómo se autentican los usuarios y los servicios? Considere la posibilidad de federar identidades, autenticación basada en certificados e identidades administradas para cargas de trabajo.
- **Modelo de acceso con privilegios**: ¿Cómo controla el acceso administrativo? Diseñe para la autorización justo a tiempo, los flujos de trabajo de aprobación y el monitoreo de sesiones.
- **Límites de autorización**: ¿Cómo se limitan los permisos? Considere la posibilidad de herencia de control de acceso basado en rol (RBAC) a través de la jerarquía del grupo de administración.

Los controles de red complementan la seguridad basada en identidades. Entre las decisiones clave se incluyen:

- **Estrategia de segmentación**: ¿Cómo se aíslan las cargas de trabajo? Diseñe límites de red que limiten el movimiento lateral y contengan posibles infracciones.
- **Inspección del** tráfico: ¿Dónde se inspecciona el tráfico? Determine los puntos de inspección para los flujos de tráfico norte-sur (Internet) y este-oeste (interno).
- **Modelo de conectividad**: ¿Cómo se conectan las cargas de trabajo a recursos locales, Internet y entre sí? Diseñe la conectividad que permite la supervisión y el control de seguridad.
- **Requisitos de cifrado**: ¿Dónde necesita el cifrado en tránsito? Considere la posibilidad de cifrar entre regiones, en el entorno local y en el entorno en la nube.

El **Well-Architected Framework** es la guía de Microsoft para diseñar y operar cargas de trabajo de alta calidad en Azure. Aunque **Cloud Adoption Framework** guía su *recorrido* a la nube y las zonas de aterrizaje de Azure proporcionan la *base* para su entorno, el marco de Well-Architected se centra en la excelencia de la *carga de trabajo*, lo que garantiza que cada aplicación que compile cumpla los estándares de calidad.

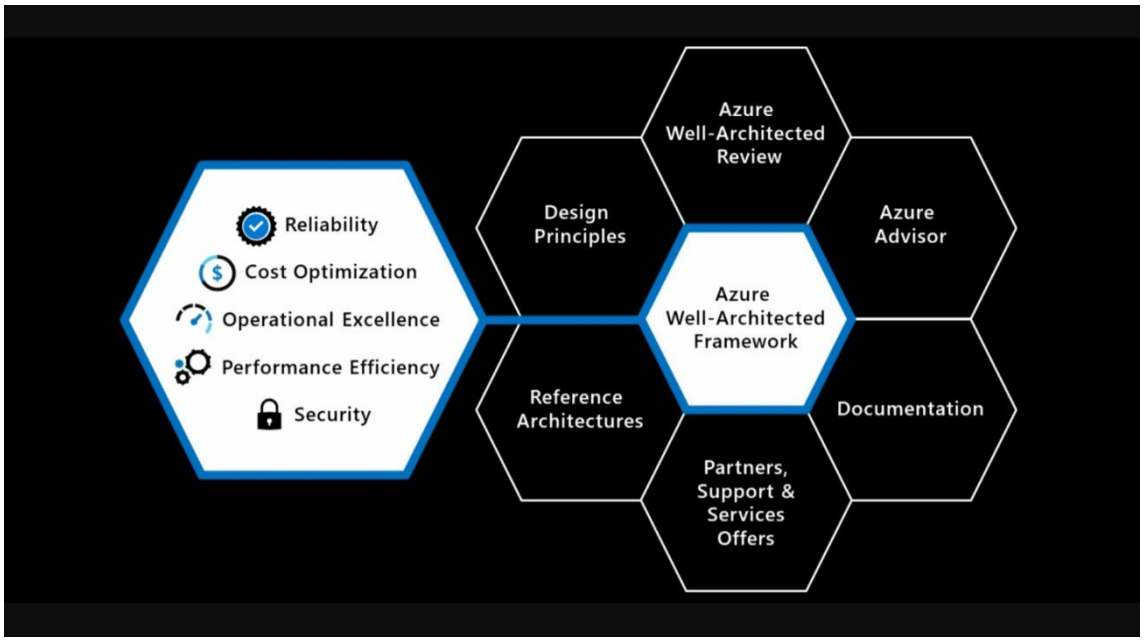
Estos tres marcos funcionan juntos:

- **Cloud Adoption Framework**: define la estrategia de nube y el enfoque de adopción
- **Zonas de aterrizaje de Azure**: implementa un entorno seguro y regulado alineado con los principios de CAF
- **Marco de buena arquitectura**: guía el diseño de cargas de trabajo individuales implementadas en las zonas de aterrizaje

Como arquitecto de ciberseguridad, comprender este marco es esencial porque las decisiones de seguridad no existen de forma aislada, deben equilibrarse con los requisitos operativos, costo y confiabilidad.

El marco consta de **cinco** pilares:

Fundamento	Descripción	Enfoque del arquitecto de seguridad
Reliability	Resistencia, disponibilidad y recuperación	Asegúrese de que los controles de seguridad no creen puntos únicos de error.
Security	Protección de datos, detección de amenazas y mitigación	Protección de la confidencialidad, integridad y disponibilidad
Optimización de costos	Modelado de costos, presupuestos y reducción de residuos	Inversiones de seguridad de tamaño correcto para el nivel de riesgo
Excelencia operativa	Prácticas holísticas de observabilidad y DevOps	Integración de la seguridad en canalizaciones de implementación
Eficiencia del rendimiento	Escalabilidad y pruebas de carga	Asegurarse de que los controles de seguridad no se conviertan en cuellos de botella



El marco de Well-Architected se estructura en capas que se basan entre sí:

Los pilares forman la base. Cada pilar proporciona principios de diseño, listas de comprobación, patrones de diseño en la nube e instrucciones sobre los inconvenientes. El pilar de seguridad aborda específicamente la tríada de la

CIA (confidencialidad, integridad, disponibilidad) a través de un enfoque de Confianza Cero.

La guía de carga de trabajo aplica principios de pilar a tipos de carga de trabajo específicos. Esto incluye instrucciones dedicadas para las cargas de trabajo de inteligencia artificial, que aborda desafíos únicos, como la gobernanza del modelo, los ataques de inyección de mensajes y la filtración de datos a través de la inferencia.

Las guías de servicio proporcionan recomendaciones de configuración para servicios individuales de Azure, lo que le ayuda a implementar controles de seguridad en el nivel de recursos.

El pilar de seguridad se basa en los principios de confianza cero que todos los arquitectos de ciberseguridad deben internalizar:

- **Comprobar explícitamente**: autentique y autorice en función de todos los puntos de datos disponibles, incluida la identidad, la ubicación, el estado del dispositivo y la clasificación de datos.
- **Uso del acceso con privilegios mínimos**: limite el acceso con directivas Just-In-Time (JIT) y Just-Enough-Access (JEA), directivas adaptables basadas en riesgos y protección de datos.
- **Asumir que hay brechas**: minimice el radio de expansión y el acceso a los segmentos. Compruebe el cifrado de un extremo a otro y use análisis para la detección de amenazas y la mejora de la defensa.

La seguridad constituye uno de los aspectos más importantes de cualquier arquitectura. Proporciona las siguientes garantías contra ataques deliberados y abuso de sus valiosos datos y sistemas:

- Confidencialidad
- Integridad
- Disponibilidad

Los equipos especialistas en proveedores en la nube pueden desarrollar funcionalidades avanzadas para operar y proteger sistemas en nombre de las organizaciones. Este enfoque es preferible a numerosas organizaciones que desarrollan individualmente conocimientos profundos sobre la administración y protección de elementos comunes, como:

- Seguridad física del centro de datos
- Actualización de firmware
- Configuración del hipervisor

Los principios de confianza cero del pilar de seguridad se aplican directamente a las cargas de trabajo de inteligencia artificial:

Principio de confianza cero	Aplicación de IA
Comprobación explícita	Autenticar todas las solicitudes a los puntos de conexión de IA; validar el contenido de entrada antes del procesamiento
Privilegio mínimo	Restringir el acceso del modelo a los usuarios autorizados; limitar la exposición de los datos de entrenamiento al mínimo necesario
Asumir que hay una brecha	Implementar el filtrado de contenido en los resultados; supervisar intentos de inyección de comandos y de jailbreak

Los objetivos de seguridad efectivos son:

- **Alineado con la empresa**: las inversiones en seguridad deben proteger lo que más importa a la organización
- **Basado en riesgos**: priorizar los controles en función de la probabilidad de amenaza y el impacto empresarial
- **Medible**: Definir métricas que demuestren la mejora en la postura de seguridad

Cada diseño de seguridad de carga de trabajo debe abordar los tres principios básicos de seguridad: confidencialidad, integridad y disponibilidad (CIA):

- **Confidencialidad**: ¿Quién puede acceder a los datos? ¿Cómo está protegido en reposo y en tránsito?
- **Integridad**: ¿Cómo se evita la modificación no autorizada? ¿Cómo detecta alteraciones?
- **Disponibilidad**: ¿Cómo se protege contra la denegación de servicio? ¿Cuáles son los objetivos de recuperación?

Controles de seguridad de capa para que un error de un control no ponga en peligro la carga de trabajo:

1. **Capa de identidad**: autenticación y autorización
2. **Capa de red**: segmentación y filtrado de tráfico
3. **Capa de aplicación**: validación de entrada, prácticas de codificación seguras
4. **Capa de datos**: cifrado, controles de acceso, copia de seguridad y recuperación

El **Marco de adopción de seguridad de Microsoft (SAF)** es una guía completa para la modernización de la seguridad de un extremo a otro. Proporciona un enfoque estructurado, desde la estrategia ejecutiva hasta la arquitectura y la planificación técnica, que se basan en los principios de Confianza cero, para ayudar a las organizaciones a mejorar su posición de seguridad en un entorno híbrido y multinube.

SAF proporciona el "por qué y cómo" de la modernización de la seguridad (la hoja de ruta estratégica y la guía operativa), mientras que **MCRA** proporciona el "qué" (la arquitectura detallada de las capacidades de seguridad).

MCRA es básicamente el plano técnico que visualiza cómo todas las funcionalidades de seguridad de Microsoft y los procedimientos recomendados

se ajustan en una arquitectura de un extremo a otro. Muestra cómo implementar las instrucciones de SAF en el nivel técnico.

Las arquitecturas de referencia de ciberseguridad de Microsoft (MCRA) describen las funcionalidades de ciberseguridad de Microsoft y cómo se integran con las arquitecturas de seguridad existentes. McRA proporciona:

- **Diagramas técnicos** que muestran cómo se integran las funcionalidades de seguridad de Microsoft con las plataformas de Microsoft (Microsoft 365 y Azure), aplicaciones que no son de Microsoft (ServiceNow, Salesforce) y plataformas en la nube que no son de Microsoft (AWS, GCP).
- **Descripciones de capacidades** con consejos en pantalla que proporcionan breves explicaciones y vínculos a la documentación al ver en modo de presentación.
- **Guía de procedimientos recomendados** para implementar funcionalidades de seguridad en el entorno empresarial.

La seguridad de la inteligencia artificial abarca dos cuestiones relacionadas:

- **Protección de sistemas de inteligencia artificial** : protección de modelos de inteligencia artificial, datos de entrenamiento y aplicaciones con tecnología de inteligencia artificial frente a ataques como robo de modelos, intoxicación de datos y inyección de mensajes.
- **Uso de la inteligencia artificial para la seguridad** : uso de funcionalidades de inteligencia artificial para mejorar la detección de amenazas, automatizar las operaciones de seguridad y mejorar la posición de seguridad a través de herramientas como Microsoft Security Copilot.

Microsoft Cloud Security Benchmark v2 (MCSB) es una colección de recomendaciones de seguridad de alto impacto que puede usar para ayudar a proteger los servicios en la nube en Azure y otros entornos en la nube, como AWS y GCP. Proporciona un marco completo de procedimientos recomendados de seguridad con opciones de configuración específicas e instrucciones que puede supervisar en varias plataformas en la nube.

Este referente se centra en las áreas de seguridad orientadas a la nube, incorporando un amplio conjunto de marcos de seguridad holísticos de Microsoft y del sector, incluyendo:

- **Cloud Adoption Framework**: Microsoft Cloud Adoption Framework para Azure (CAF) ofrece instrucciones completas y paso a paso para el éxito de la adopción de la nube.
- **Azure Well-Architected Framework**: Azure Well-Architected Framework (WAF) es un marco de diseño y un conjunto de procedimientos recomendados que ayudan a los arquitectos y desarrolladores a crear cargas de trabajo de alta calidad en Microsoft Azure.
- **Microsoft Secure Future Initiative**: Microsoft Secure First Initiative (SFI) es una iniciativa de Microsoft iniciada para insertar la seguridad en cada fase del diseño, desarrollo y operaciones del producto. La evolución continua de SFI informa sobre la innovación, el desarrollo y los procedimientos recomendados de seguridad en Microsoft. También nos proporciona oportunidades continuas para trabajar con clientes y el sector de seguridad más amplio para fortalecer nuestras defensas colectivas.
- **Estándares y marcos de mejores prácticas de seguridad de otros proveedores de servicios de la industria y en la nube**: entre los ejemplos se incluyen el Marco Well-Architected de Amazon Web Services (AWS), los Controles del Center for Internet Security (CIS), el Instituto Nacional de Estándares y Tecnología (NIST) y el Estándar de Seguridad de Datos para la Industria de Tarjetas de Pago (PCI-DSS).

Término	Description	Example
Dominio de seguridad	Agrupación de alto nivel de controles de seguridad relacionados que abordan un área específica de preocupación de seguridad.	La seguridad de inteligencia artificial es uno de los 12 dominios de seguridad de MCSB v2. Agrupa todos los controles de seguridad relacionados con la protección de cargas de trabajo y servicios de inteligencia artificial.
Control de seguridad	Un requisito o recomendación de seguridad específicos dentro de un dominio que debe abordarse. Los controles de seguridad son descripciones independientes de la tecnología de lo que debe lograr.	Dentro del dominio de protección de datos, "DP-1: Detectar, clasificar y etiquetar datos confidenciales" es un control de seguridad que describe la necesidad de identificar y clasificar información confidencial.
Subcontrol de seguridad	Una recomendación detallada y granular o una guía de implementación que respalda un control de seguridad. Un subcontrol de seguridad proporciona pasos técnicos o de procedimientos específicos.	Bajo el control de seguridad DP-1, el subcontrol de seguridad DP-1.1 proporciona instrucciones específicas para implementar la clasificación de datos mediante Microsoft Purview o herramientas similares.
Línea base	Conjunto de implementaciones de control de seguridad adaptadas a un escenario específico, marco de cumplimiento o sector.	Aunque las líneas de base para MCSB v2 (versión preliminar) aún no están disponibles, puede encontrar información sobre las líneas base de MCSB v1 en Introducción a la prueba comparativa de seguridad en la nube de Microsoft v1.

Las líneas de base de seguridad son documentos estandarizados para las ofertas de productos de Azure, que describen las funcionalidades de seguridad disponibles y las configuraciones de seguridad óptimas que le ayudarán a reforzar la seguridad mediante herramientas, seguimiento y características de seguridad mejoradas. Las líneas base de seguridad para Azure se centran en áreas de control centradas en la nube en entornos de Azure.

La identidad es la base de la seguridad de Confianza cero. Un proveedor de identidades centralizado actúa como motor de directivas para tomar decisiones de acceso. Entre los procedimientos clave se incluyen:

- **Centralice la identidad y habilite la autenticación segura**: use un único proveedor de identidades centralizado. Aplique la autenticación multifactor (MFA) para todos los usuarios, bloquee la autenticación heredada y use métodos sin contraseña siempre que sea posible.
- **Aplicar directivas de acceso condicional**: evalúe cada solicitud de acceso en tiempo real en función del rol de usuario, el cumplimiento de dispositivos, la ubicación y las señales de riesgo. Bloquear inicios de sesión de alto riesgo y garantizar el cumplimiento de dispositivos para aplicaciones sensibles.
- **Protección de cuentas con privilegios**: implemente privilegios mínimos con el control de acceso basado en roles (RBAC), use la elevación Just-In-Time para el acceso administrativo, mantenga cuentas

de administrador independientes y requiera estaciones de trabajo de acceso con privilegios (PAW) para tareas confidenciales.

- **Controlar y supervisar identidades**: automatice el ciclo de vida de las identidades con la integración de RR. HH., realice revisiones de acceso periódicas y supervise las anomalías de inicio de sesión con soluciones de protección de identidades y administración de información y eventos de seguridad (SIEM).

Confianza cero requiere la comprobación continua de la posición de seguridad del dispositivo. Entre los procedimientos clave se incluyen:

- **Inscribir dispositivos y aplicar el cumplimiento**: administre todos los dispositivos corporativos con una solución de administración de dispositivos móviles (MDM) mediante directivas de cumplimiento (cifrado, aplicación de revisiones, antivirus). Use señales de cumplimiento en el acceso condicional para restringir el acceso desde dispositivos no compatibles
- **Implementar detección y respuesta de puntos de conexión (EDR): implemente soluciones EDR** en todos los puntos de conexión para la detección de amenazas, la respuesta automatizada y la administración de vulnerabilidades. Habilite la protección contra alteraciones.
- **Administrar actualizaciones y vulnerabilidades**: use la administración centralizada de revisiones. Busque vulnerabilidades continuamente y aplique el control de aplicaciones en entornos de alto riesgo.
- **Protección de BYOD y dispositivos móviles**: use directivas de administración de aplicaciones móviles (MAM) para dispositivos personales. Aplique controles de sesión de acceso condicional a través de un agente de seguridad de acceso a la nube (CASB) para limitar las descargas de datos en dispositivos no administrados.

Los controles de red siguen siendo esenciales para la contención de infracciones y defensa en profundidad. Entre los procedimientos clave se incluyen:

- **Segmentar y restringir el acceso a la red**: use grupos de seguridad de red, subredes y firewalls para limitar el movimiento lateral. Permitir solo el tráfico necesario entre segmentos
- **Perímetro de red de nube seguro**: use cortafuegos y cortafuegos de aplicaciones web (WAF) para la inspección del tráfico. Habilite la protección contra DDoS, use el acceso Just-In-Time para los puertos de administración y aplique TLS para todas las aplicaciones web.

- **Uso del acceso privado**: use puntos de conexión privados y puntos de conexión de servicio para los servicios PaaS. Implemente Acceso a la Red de Confianza Cero (ZTNA) en lugar de la VPN heredada para el acceso remoto.
- **Supervisión del tráfico de red**: analice los registros de flujo de red, habilite el filtrado de inteligencia sobre amenazas en firewalls y supervise DNS para la actividad de comando y control (C2).

Las aplicaciones y **las canalizaciones de Azure** deben protegerse para evitar vulnerabilidades. Entre los procedimientos clave se incluyen:

- **Configuración segura de los servicios en la nube**: aplique la configuración de línea base de la prueba comparativa de seguridad a todos los servicios en la nube. Utilice identidades administradas con privilegios mínimos, almacenes seguros para secretos y aplicación de políticas para asegurar el cumplimiento.
- **Integración de DevSecOps**: inserción de pruebas estáticas de seguridad de aplicaciones (SAST), análisis de dependencias y análisis de secretos en canalizaciones de CI/CD (integración continua/entrega continua). Imponga filtros de calidad del código antes del despliegue.
- **Protección de aplicaciones en ejecución**: utilice un CASB para la supervisión de SaaS, integre las aplicaciones con el proveedor de identidades para la autenticación y use API Management con reglas de WAF. Implemente soluciones de seguridad de contenedor para cargas de trabajo de Kubernetes.
- **Protección de datos en aplicaciones**: aplique la validación de datos, el cifrado en reposo y en tránsito (TLS 1.2 y versiones posteriores) y use enmascaramiento o tokenización para datos confidenciales.

En última instancia, la seguridad consiste en proteger **los datos**. Entre los procedimientos clave se incluyen:

- **Detectar y clasificar datos confidenciales**: use herramientas de gobernanza de datos para examinar y clasificar datos en documentos, bases de datos y almacenamiento. Aplique etiquetas de confidencialidad para informar sobre las directivas de acceso y cifrado.
- **Cifrado de datos en reposo y en tránsito**: use el cifrado con claves administradas por la plataforma o administradas por el cliente y aplique TLS para todas las conexiones. Considere la posibilidad de computación confidencial para cargas de trabajo altamente confidenciales
- **Implementar la prevención de pérdida de datos (DLP): use directivas DLP** en el correo electrónico, las herramientas de

colaboración, el almacenamiento de archivos y los puntos de conexión para evitar la filtración de datos. Bloquear o alertar sobre el uso compartido no autorizado de datos confidenciales.

- **Aplicar acceso a datos con privilegios mínimos**: use etiquetas de seguridad de nivel de fila, cifrado de columnas y confidencialidad para restringir el acceso a los datos. Supervise el acceso a los datos a través de la auditoría de bases de datos y la integración de SIEM.
- **Proteger copias de seguridad**: habilite la eliminación temporal en copias de seguridad, use almacenamiento inmutable para la protección contra ransomware y pruebe la recuperación con regularidad.

Los tres marcos funcionan juntos para guiar este enfoque integrado:

- **Confianza cero** proporciona la mentalidad estratégica: nunca confiar, comprobar siempre, asumir la vulneración.
- **MCRA** garantiza la amplitud asignando todos los dominios de seguridad y mostrando cómo se interconectan.
- **MCSB** proporciona los controles específicos para poner en funcionamiento cada funcionalidad con resultados medibles.

La Arquitectura de referencia de ciberseguridad de Microsoft (MCRA) y **Microsoft Cloud Security Benchmark (MCSB)** proporcionan procedimientos recomendados para cada categoría de amenazas.

Las amenazas internas se originan en personas con acceso legítimo (empleados, contratistas o asociados) que causan daños intencionada o accidentalmente. Entre los principales riesgos se incluyen las fugas de datos, el robo de propiedad intelectual, el fraude y las infracciones de cumplimiento. Entre los procedimientos clave se incluyen:

- **Implementar el acceso con privilegios mínimos**: restrinja el acceso solo a lo que los usuarios necesitan para su rol. Use el acceso Just-In-Time para las operaciones confidenciales y realice revisiones de acceso periódicas.
- **Supervisar el comportamiento del usuario**: implemente análisis de comportamiento de entidades de usuario (UEBA) para detectar patrones de actividad anómalos, como acceso a datos inusuales, actividad fuera de horas o descargas masivas.
- **Proteger datos confidenciales**: clasificar y etiquetar datos confidenciales, aplicar directivas de prevención de pérdida de datos

(DLP) para evitar el uso compartido no autorizado y usar el cifrado para proteger los datos en reposo y en tránsito.

- **Exigir la separación de tareas**: requerir varias aprobaciones para acciones críticas, como transacciones financieras, implementaciones de código o cambios de acceso.

Los ataques externos se originan en actores de amenazas fuera de su organización: ciberdelincuentes, estados nacionales o hacktivistas. La defensa eficaz requiere inversiones equilibradas en todo el ciclo de vida de ataque: identificar, proteger, detectar, responder y recuperar. Entre los procedimientos clave se incluyen:

- **Implementar defensas superpuestas**: combine controles preventivos (firewalls, protección de puntos de conexión, controles de acceso) con controles de detección (SIEM, XDR) en todas las superficies expuestas a ataques.
- **Integración de XDR y SIEM**: use la detección y respuesta extendidas (XDR) para alertas de alta fidelidad sobre activos cubiertos, y SIEM para una amplia visibilidad y correlación en todas las fuentes de datos. Ninguno de ellos solo proporciona cobertura completa.
- **Automatización de la respuesta con SOAR**: use la orquestación de seguridad, la automatización y la respuesta (SOAR) para reducir el esfuerzo manual, acelerar la contención y liberar analistas para investigaciones complejas.
- **Preparar la respuesta a incidentes: documente** los planes de respuesta a incidentes (IR) con roles claros, cuadernos de estrategias y procedimientos de comunicación. Realice ejercicios de simulación regulares y revisiones posteriores a los incidentes.
- **Adaptarse a entornos de OT**: ajuste herramientas y procesos a las restricciones de la tecnología operativa: priorice la seguridad, use detección de red pasiva y aísle los sistemas heredados que no se pueden actualizar.

Los ataques de la cadena de suministro ponen en peligro a proveedores de confianza, software o servicios para obtener acceso a su entorno. Estos ataques son especialmente peligrosos porque omiten las defensas perimetrales tradicionales. Entre los procedimientos clave se incluyen:

- **Comprobar la integridad del software**: Valide firmas de código, sumas de comprobación y listas de materiales de software (SBOM) antes de la implementación. Supervisar la manipulación en canalizaciones de CI/CD.

- **Evaluar el riesgo de terceros**: evalúe los procedimientos de seguridad del proveedor antes de la incorporación. Incluya los requisitos de seguridad en los contratos y lleve a cabo revisiones periódicas.
- **Limitar el acceso de terceros**: aplique privilegios mínimos a las cuentas de proveedor y las conexiones de servicio. Use cuentas dedicadas con acceso limitado a tiempo y supervise toda la actividad de terceros.
- **Aislar integraciones externas**: Segmentar redes y sistemas que se conectan a terceros. Use puertas de enlace de API con controles de seguridad para integraciones de servicios externos.

Los hilos comunes en todos los tipos de ataque son:

- **Asumir vulneración** – Diseñar controles que limiten los daños cuando las medidas preventivas fallan
- **Supervisión continua**: detección de anomalías en la identidad, la red, el punto de conexión y los datos
- **Respuesta rápida** : automatización de la contención y mantenimiento de planes de respuesta a incidentes probados

La seguridad de la inteligencia artificial se basa en la arquitectura de seguridad existente a la vez que aborda riesgos únicos. Los controles de IA de MCSB v2 (AI-1 a AI-7) proporcionan un marco completo organizado en torno a tres pilares:

- **Seguridad de la plataforma** : proteja los modelos, los datos de entrenamiento y la infraestructura mediante la gobernanza de modelos aprobada y la seguridad de la cadena de suministro.
- **Seguridad de las aplicaciones** – defensa contra la inyección de instrucciones y ataques adversariales a través del filtrado de contenido, meta-instrucciones de seguridad, el principio de privilegio mínimo y supervisión humana
- **Supervisión y respuesta** : detecte amenazas y valide los controles a través de la supervisión continua y la formación de equipos rojos de IA

Microsoft proporciona un **Plan de Modernización Rápida de Confianza Cero (RaMP)** a través de su marco de adopción de Confianza Cero. RaMP no es una lista de comprobación independiente: es un enfoque estructurado y por fases para modernizar rápidamente la posición de seguridad alineando los objetivos técnicos con las prioridades empresariales.

Confianza cero es una estrategia de seguridad, no un producto. Elimina la suposición de que cualquier cosa dentro de la red corporativa es segura. Tres principios básicos guían cada decisión de diseño que tome:

- **Compruebe explícitamente**. Siempre autenticar y autorizar en función de todos los puntos de datos disponibles, lo que incluye la identidad del usuario, la ubicación, el estado del dispositivo, el servicio o la carga de trabajo, la clasificación de datos y las anomalías.
- **Use el acceso con privilegios mínimos**. Limite el acceso de los usuarios con los modelos just-in-time y just-enough-access (JIT/JEA), directivas que se adaptan al nivel de riesgo y protección de datos.
- **Asumir una brecha**. Minimice el radio de impacto y el acceso a los segmentos. Compruebe el cifrado de un extremo a otro y use análisis para aumentar la visibilidad, impulsar la detección de amenazas y mejorar las defensas.

Estos principios se aplican en siete pilares tecnológicos: **identidades**, **puntos de conexión**, **aplicaciones**, **datos**, **infraestructura**, **red** y **visibilidad, automatización y orquestación**.

El marco de adopción de Confianza cero organiza una modernización rápida en torno a un ciclo de vida con cinco fases:

1. **Definir estrategia**. Alinee las prioridades de seguridad con los resultados empresariales y obtenga el apoyo de la alta dirección presentando la seguridad como una responsabilidad empresarial compartida.
2. **Plan**. Dé prioridad a los avances rápidos e incrementales mediante un modelo de madurez de cuatro fases.
3. **Listo**. Evalúe, pruebe y pilote las configuraciones de seguridad con un enfoque ágil.
4. **Adoptar**. Implemente de forma incremental protecciones en áreas funcionales.
5. **Controlar y administrar**. Realiza un seguimiento del progreso, vigila las amenazas e itera hacia la madurez.

Según el Informe de Defensa Digital de Microsoft, el 98 % de los ataques se puede detener con medidas de higiene básicas, entre las que se incluyen:

- Habilitación de MFA para todos los usuarios

- Aplicación de principios de acceso con privilegios mínimos
- Mantener el software y los sistemas actualizados
- Implementación de protección contra malware
- Protección de datos confidenciales con clasificación y cifrado

El acceso con privilegios es el objetivo de valor más alto para los atacantes. Una cuenta administrativa comprometida permite el movimiento lateral rápido, la filtración de datos y la implementación de ransomware. El diseño de Confianza cero debe abordar el acceso con privilegios como prioridad:

- **Separe las cuentas con privilegios y estándar**. Los administradores deben usar cuentas dedicadas para tareas con privilegios, independientes de las cuentas de productividad diarias. Esto previene que un compromiso de correo electrónico escale de inmediato a un acceso administrativo.
- **Habilite Privileged Identity Management (PIM).** Implemente el acceso just-in-time para roles con privilegios con límites de tiempo y flujos de trabajo de aprobación. Las asignaciones de roles permanentes crean objetivos fijos.
- **Implemente estaciones de trabajo de acceso con privilegios**. Restrinja las tareas administrativas a estaciones de trabajo protegidas aisladas del correo electrónico, la exploración web y otras actividades de alto riesgo.
- **Cree cuentas de acceso de emergencia**. Establezca cuentas de emergencia con protección mediante tokens de seguridad de hardware y pruébelas con regularidad.

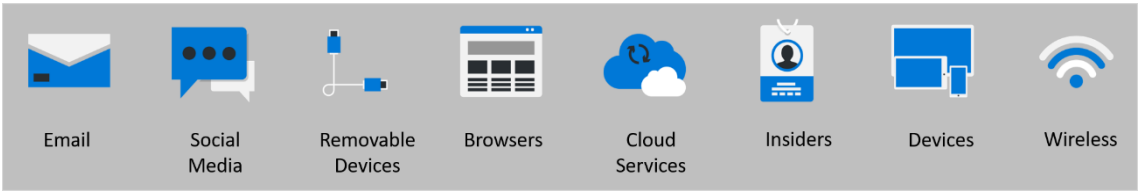
¿Qué es el panorama de amenazas?

Independientemente de si una organización es grande o pequeña, el panorama digital completo con el que interactúa representa un punto de entrada para un ciberataque. Entre estos se pueden incluir:

- cuentas de Email
- Cuentas de redes sociales
- Dispositivos móviles
- La infraestructura tecnológica de la organización
- Servicios en la nube

- Personas

Un vector de ataque es un punto de entrada o una ruta para que un atacante obtenga acceso a un sistema.



Cualquier ataque que da lugar a que alguien obtenga acceso no autorizado a dispositivos, servicios o redes se **considera una infracción de seguridad**. Imagine una infracción de seguridad como similar a un allanamiento en el que un intruso (atacante) logra entrar en un edificio (un dispositivo, una aplicación o una red).

Las infracciones de seguridad tienen diferentes formas, entre las que se incluyen las siguientes:

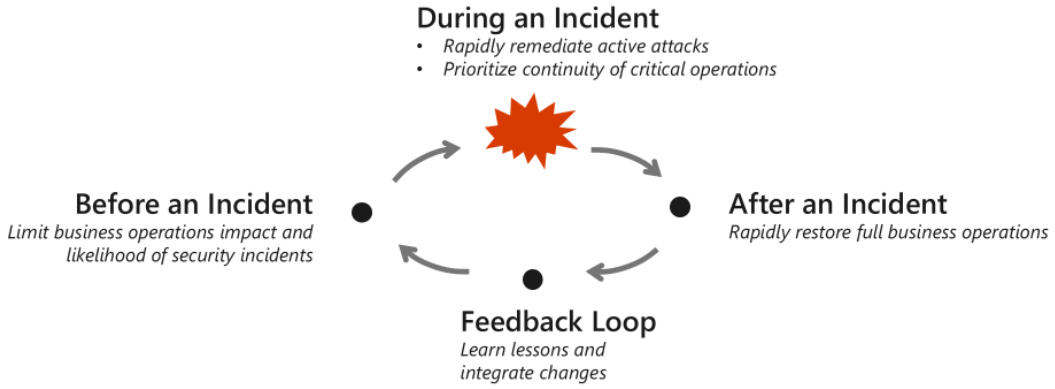
- **Ataques de ingeniería social**: en ingeniería social, los ataques de suplantación se producen cuando un usuario no autorizado (el atacante), tiene como objetivo obtener la confianza de un usuario autorizado posando como persona de autoridad para acceder a un sistema desde alguna actividad nefariosa. Las herramientas con tecnología de inteligencia artificial permiten a los atacantes crear audio o vídeo falso convincente, lo que hace que los ataques de suplantación sean más sofisticados y más difíciles de detectar.
- **Ataques de explorador**: ya sea en un escritorio, portátil o teléfono, los exploradores son una herramienta de acceso importante para Internet. Las vulnerabilidades de seguridad de un explorador pueden tener un impacto significativo debido a su generalización.
- **Ataques de contraseña**: un ataque de contraseña es cuando alguien intenta usar la autenticación de una cuenta protegida con contraseña para obtener acceso no autorizado a un dispositivo o sistema. Los atacantes suelen usar software para acelerar el proceso de descifrar y adivinar contraseñas.

Una infracción de datos es cuando un atacante logra acceder a los datos o controlarlos.

Una cadena de ataque describe la cadena típica de eventos durante un ataque que conduce a daños en la organización. Esto incluye los pasos

técnicos y no técnicos realizados por adversarios o usuarios internos durante el ataque.

La resiliencia requiere tener una visión pragmática que supone una violación. Necesita una inversión continua en todo el ciclo de vida del riesgo de seguridad.



- **Antes de un incidente:** Mejore continuamente la posición de seguridad y la capacidad de la organización para responder a un incidente. La mejora continua de la posición de seguridad ayuda a limitar la probabilidad y el posible impacto de un incidente de seguridad en las operaciones y los recursos empresariales.
- **Durante un incidente:** Las operaciones empresariales deben continuar durante un incidente, incluso si están degradadas, más lentas o limitadas solo a sistemas críticos. Las dos prioridades principales durante un incidente son:
    - **Proteger las operaciones críticas:** Si se amenaza, todos los esfuerzos deben centrarse en proteger y mantener operaciones empresariales críticas en todas las demás funciones.
    - **Evitar daños adicionales:** La prioridad predeterminada para las operaciones de seguridad es detectar la extensión completa del acceso del atacante y, a continuación, expulsarlas rápidamente del entorno. Al expulsarlos, se impedirá a los atacantes ocasionar más daños, incluidas posibles represalias.
- **Después de un incidente:** Si las operaciones empresariales están dañadas durante un ataque, las reparaciones deben iniciarse inmediatamente para restaurar las operaciones empresariales completas. Estas reparaciones se aplican incluso si eso significa restaurar operaciones sin datos que se perdieron en un ataque.

- **Circuito de retroalimentación:** Los atacantes se repiten o repiten lo que otros atacantes han encontrado que funciona. Los atacantes aprenden de atacar a su organización, por lo que debe aprender continuamente de sus ataques.

La resiliencia de seguridad se centra en apoyar la resiliencia de su negocio.

- **Permitir que su negocio** innove y se adapte rápidamente al entorno empresarial cambiante. La seguridad siempre debe buscar formas seguras de decir *sí* a la innovación empresarial y la adopción de la tecnología.
- **Limite el impacto** y la probabilidad de interrupciones antes, durante y después de los ataques activos a las operaciones empresariales.

La resistencia requiere una estrecha asociación entre las partes interesadas de la empresa, profesionales de TI y líderes, y profesionales de seguridad.

Los procedimientos recomendados de Microsoft para la protección contra ransomware se basan en un enfoque de tres pasos:

1. Preparación de un plan de recuperación
2. Limitar el alcance del daño
3. Dificultar la entrada

Azure Backup ofrece seguridad al entorno de copia de seguridad, tanto si los datos están en tránsito como en reposo. Con Azure Backup, puede hacer una copia de seguridad de lo siguiente:

- Archivos, carpetas y estado del sistema locales
- VM Windows o Linux enteras
- Azure Managed Disks
- Recursos compartidos de archivos de Azure en una cuenta de almacenamiento
- Bases de datos de SQL Server que se ejecutan en VM de Azure
- Bases de datos de SAP HANA que se ejecutan en máquinas virtuales de Azure

Azure Backup proporciona varias capas de protección contra ransomware:

- **Almacenes inmutables: habilite almacenes inmutables** para evitar la eliminación o modificación de los datos de copia de seguridad durante

un período de retención especificado. Una vez habilitada la inmutabilidad, no se puede deshabilitar, lo que proporciona una protección segura contra la eliminación malintencionada.

- **Autorización multiusuario (MUA):** requerir a varios usuarios que aprueben operaciones críticas, como deshabilitar la eliminación temporal o modificar directivas de copia de seguridad, lo que impide que una sola cuenta de administrador en peligro sabote las copias de seguridad.
- **Eliminación** temporal: los datos de copia de seguridad eliminados se conservan durante 14 días adicionales, lo que permite la recuperación incluso si un atacante elimina las copias de seguridad o accidentalmente.
- **PIN de** seguridad: requerir un PIN de seguridad para las operaciones críticas para agregar una capa de autenticación adicional.
- **Cifrado**: todos los datos de copia de seguridad se cifran en reposo mediante el cifrado de Azure Storage y en tránsito mediante HTTPS/TLS.

Las funcionalidades con tecnología de inteligencia artificial mejoran la protección de copia de seguridad:

- **La detección de anomalías** usa el aprendizaje automático para identificar patrones de copia de seguridad inusuales que pueden indicar un ataque ransomware en curso
- **Las alertas inteligentes** reducen los falsos positivos mediante el aprendizaje del comportamiento normal de copia de seguridad y la marcación de amenazas originales
- **El análisis predictivo** puede predecir posibles errores de copia de seguridad o problemas de capacidad antes de que afecten a las funcionalidades de recuperación.

Las cargas de trabajo de aplicaciones empresariales y de organización tienen requisitos de objetivo de tiempo de recuperación (RTO) y de objetivo de punto de recuperación (RPO). El diseño eficaz de continuidad empresarial y recuperación ante desastres (BCDR) proporciona funcionalidades de nivel de plataforma que cumplen estos requisitos.

Update Manager es un servicio unificado que ayuda a administrar y controlar las actualizaciones de todas las máquinas. Puede supervisar el cumplimiento de las actualizaciones de Windows y Linux en las implementaciones de Azure, en el entorno local y en otras plataformas en la nube desde un único panel.

Diseño de funcionalidades de operaciones de seguridad, identidad y cumplimiento

El **cumplimiento normativo** hace referencia a la materia de asegurarse de que una organización siga las leyes que aplican los organismos reguladores en su geografía o reglas requeridas voluntariamente por las normas del sector adoptadas voluntariamente.

Reglamento/Estándar	Ámbito	Requisitos clave
Ley de inteligencia artificial de la UE	Organizaciones que implementan inteligencia artificial en la UE	Clasificación basada en riesgos, obligaciones de transparencia, evaluaciones de conformidad para la inteligencia artificial de alto riesgo
ISO/IEC 42001:2023	Estándar voluntario global	Requisitos del sistema de administración de inteligencia artificial que abarcan la gobernanza, la administración de riesgos y la mejora continua
NIST AI Risk Management Framework 1.0	Directrices estadounidenses (voluntarias)	Marco para administrar los riesgos de inteligencia artificial en todo el ciclo de vida de la inteligencia artificial
ISO/IEC 23894:2023	Estándar voluntario global	Instrucciones sobre los procesos de administración de riesgos de IA

Implicación del cumplimiento: Independientemente del modelo de servicio, siempre es responsable de los datos, los puntos de conexión, la administración de identidades y los controles de acceso. Cuando una regulación requiere "cifrado de datos en reposo", debe determinar qué controles de cifrado proporciona Microsoft de forma predeterminada y cuál debe configurar.

La **metodología de gobernanza de Cloud Adoption Framework** proporciona un proceso estructurado para traducir los requisitos de cumplimiento en directivas ejecutables.

Este ciclo de cuatro pasos garantiza la alineación continua entre los requisitos normativos y los controles técnicos:

Paso 1: Evaluación de los riesgos de cumplimiento

El primer paso para traducir los requisitos de cumplimiento es comprender qué normativas crean riesgos para su organización. El incumplimiento puede dar lugar a sanciones financieras, acciones legales, daños de reputación o pérdida de capacidad de operar en determinados mercados. Para evaluar estos riesgos, identifique qué normativas se aplican a su organización en función de:

- **Geografía** : dónde opera y dónde se encuentran los clientes
- **Sector:** sector sanitario, servicios financieros, gobierno u otros sectores regulados
- **Tipos de datos: datos** personales, datos de tarjetas de pago, información de salud protegida

Paso 2: Directivas de gobernanza de documentos

Convierta los requisitos normativos en instrucciones de directiva claras. Cada directiva debe incluir:

- **Riesgo empresarial** : riesgo normativo o empresarial que se está abordando
- **Instrucción de directiva** : requisito claro (por ejemplo, "Todas las cuentas de almacenamiento deben usar claves de cifrado administradas por el cliente")
- **Guía técnica** : implementación de la directiva en Azure

Paso 3: Aplicar directivas con controles técnicos

Implementación de directivas mediante herramientas de gobernanza de Azure:

- **Azure Policy** : definición y aplicación de estándares de configuración entre recursos
- **Grupos de administración** - aplicar directivas de forma coherente entre suscripciones
- **Microsoft Defender for Cloud** : supervisar la posición de cumplimiento de los estándares normativos
- **Microsoft Purview** : control de los datos en todo el patrimonio de datos

Paso 4: Supervisar y refinar

Establezca la supervisión continua para realizar un seguimiento del estado de cumplimiento:

- Uso del panel de cumplimiento normativo de Defender for Cloud para medir el cumplimiento
- Configuración de alertas para infracciones de directivas

- Revisión y actualización de directivas a medida que cambian las regulaciones

Al diseñar soluciones, asigne cada control normativo al pilar de confianza cero adecuado:

- **Identidad** : autenticación, aprovisionamiento de acceso, administración de acceso con privilegios
- **Dispositivos** : cumplimiento de puntos de conexión, comprobación del estado del dispositivo
- **Red** : segmentación, inspección de tráfico, controles perimetrales
- **Aplicaciones** : desarrollo seguro, seguridad de API, acceso a aplicaciones
- **Datos** : clasificación, cifrado, prevención de pérdida de datos
- **Infraestructura** : administración de configuración, administración de vulnerabilidades

Microsoft Purview proporciona una plataforma unificada para la seguridad, la gobernanza y el cumplimiento de los datos.

Área de solución	Propósito	Soluciones clave
Seguridad de datos	Protección de datos confidenciales en su ciclo de vida	Information Protection, Prevención de pérdida de datos, Administración de riesgos internos
Gobernanza de datos	Administración y catalogación de datos en todo el patrimonio	Mapa de datos, Catálogo unificado
Cumplimiento de datos	Cumplir los requisitos normativos y prepararse para las auditorías	Administrador de cumplimiento, Auditoría, eDiscovery, Administración de registros

Microsoft Purview Data Loss Prevention (DLP) supervisa y controla cómo se comparten los datos confidenciales en los servicios, puntos de conexión y aplicaciones en la nube de Microsoft 365.

Microsoft Purview Audit captura las actividades de usuario y administrador en los servicios de Microsoft 365.

Microsoft Purview eDiscovery le ayuda a identificar, conservar, recopilar y exportar contenido para asuntos legales.

Data Security Posture Management (DSPM) proporciona visibilidad y control tanto para las aplicaciones tradicionales como para las aplicaciones de inteligencia artificial.

Microsoft Priva es una solución de privacidad dedicada independiente de las funcionalidades de cumplimiento y protección de datos en Microsoft Purview. Aunque Purview se centra en la seguridad de los datos y el cumplimiento ampliamente, Priva aborda específicamente las operaciones de privacidad:

Solución priva	Propósito	Requisitos de privacidad resueltos
Administración de riesgos de privacidad	Identificación y corrección de riesgos de privacidad	Minimización de datos, limitación de propósitos, restricciones de transferencia
Solicitudes de derechos del interesado	Cumplimiento de solicitudes de datos individuales	Derechos de acceso, derechos de eliminación, derechos de portabilidad
Evaluaciones de privacidad	Evaluación del impacto en la privacidad de los proyectos	Privacidad por diseño, evaluaciones de impacto
Administración de consentimiento	Seguimiento y administración del consentimiento del usuario	Requisitos de consentimiento, administración de preferencias

Azure Policy evalúa los recursos con respecto a las reglas de negocio definidas en formato JSON. Estas reglas determinan si las configuraciones de recursos cumplen los requisitos de cumplimiento. Al diseñar la arquitectura de directivas, comprenda los componentes clave:

Componente	Propósito	Consideraciones de diseño
Definiciones de directivas	Definición de reglas de cumplimiento individuales	Asignar cada control normativo a propiedades de recursos específicas
Definiciones de iniciativa	Agrupar políticas relacionadas	Alineación de iniciativas con marcos de cumplimiento o dominios de seguridad
Assignments	Aplicación de directivas a ámbitos específicos	Jerarquía de ámbito de diseño para una aplicación coherente con las excepciones adecuadas
Exenciones	Exclusión de recursos específicos de la evaluación de directivas	Establecimiento de la gobernanza para exenciones limitadas por tiempo con documentación adecuada

Microsoft Defender for Cloud proporciona una evaluación continua del cumplimiento en todo el entorno multinube. Como arquitecto de seguridad, diseña cómo Defender for Cloud supervisa la posición de cumplimiento,

identifica las brechas e integra con su arquitectura de cumplimiento más amplia para proporcionar evidencia de auditorías y consultas normativas.

La identidad es el perímetro de seguridad principal en entornos híbridos y en la nube.

Microsoft Entra Internet Access es una puerta de enlace web segura (SWG) basada en identidades que protege el acceso a aplicaciones SaaS y destinos de Internet.

Microsoft Entra Private Access reemplaza las VPN tradicionales por acceso de red de confianza cero (ZTNA).

Microsoft Entra ID sirve como plataforma de identidad fundamental para las organizaciones que operan en entornos híbridos y multinube.

Microsoft Entra Cloud Sync es un servicio ligero de aprovisionamiento administrado por la nube que sincroniza usuarios, grupos y contactos de Active Directory local con el identificador de Microsoft Entra. Usa un agente de aprovisionamiento que actúa como puente entre AD y la nube.

Microsoft Entra Connect Sync es la aplicación de sincronización local para escenarios que requieren funcionalidades más allá de lo que cloud Sync ofrece actualmente.

El método de autenticación determina dónde se produce la validación de contraseñas y afecta a la seguridad, la resistencia y la experiencia del usuario.

Método	Dónde se validan las contraseñas	Consideraciones clave
Sincronización de hash de contraseñas (PHS)	Microsoft Entra ID	Implementación más sencilla; habilita la detección de credenciales filtradas a través de la protección de id. de Entra de Microsoft; proporciona resistencia en la nube si la infraestructura local no está disponible
Autenticación de paso directo (PTA)	AD local en las instalaciones	Las contraseñas nunca dejan el entorno local; aplica directivas de contraseñas locales en tiempo real; requiere que los agentes locales estén disponibles
Federación (AD FS o de un tercero)	Servidor de federación local	Admite escenarios complejos que requieren evaluación de directivas locales; habilita la autenticación de tarjetas inteligentes y certificados; agrega complejidad de la infraestructura

El identificador externo aborda dos escenarios principales a través de diferentes configuraciones de inquilino:

Scenario	Tipo de inquilino	Caso de uso principal
Colaboración B2B	Inquilino de recursos	Asociados, proveedores y contratistas que acceden a las aplicaciones de Microsoft 365 de su organización, SharePoint, Teams y aplicaciones de línea de negocio
Identidad del cliente (CIAM)	Inquilino externo	Consumidores y clientes comerciales que acceden a aplicaciones personalizadas con experiencia de inicio de sesión exclusiva de la marca

La **configuración del acceso de entrada** controla si los usuarios de organizaciones externas con Microsoft Entra pueden acceder a los recursos de su organización. Puede aplicar esta configuración a todos los usuarios o especificar usuarios, grupos y aplicaciones individuales.

La **configuración de acceso de salida** controla si los usuarios pueden acceder a los recursos de una organización externa. Al igual que las configuraciones entrantes, puede aplicar estas configuraciones a usuarios, grupos y aplicaciones específicos.

La configuración de confianza determina si las directivas de acceso condicional confían en las afirmaciones de organizaciones externas:

- **Notificaciones de MFA**: acepte la autenticación multifactor completada en el inquilino principal del usuario
- **Reclamaciones de conformidad de dispositivos** - Confiar en el estado de conformidad de dispositivos de las organizaciones asociadas
- **Notificaciones de dispositivos híbridos unidos de Microsoft Entra**: acepte el estado de unión híbrida de inquilinos externos

Un **tenant externo** es un tenant dedicado de Microsoft Entra configurado exclusivamente para las aplicaciones que tú publiques para consumidores o clientes empresariales.

Microsoft Entra External ID con **CIAM (Customer Identity and Access Management)** permite:

- Registro de autoservicio
- Experiencias de inicio de sesión personalizadas (branding)
- Escalar a **millones de usuarios consumidores**

- Mantener **separación total del directorio corporativo**

El acceso condicional es el motor de directivas de confianza cero que evalúa todas las solicitudes de acceso en las condiciones definidas y aplica los controles adecuados antes de conceder acceso a aplicaciones y datos.

Las directivas de acceso condicional evalúan varias señales para determinar el nivel de riesgo de cada intento de acceso:

- **Pertenencia a usuarios y grupos** : quién solicita acceso
- **Aplicación a la que se accede** : qué recurso es el destino
- **Estado del dispositivo**: ¿El dispositivo es compatible, unido de forma híbrida o administrado?
- **Ubicación** : donde se origina la solicitud (intervalos IP, países o regiones, ubicaciones con nombre)
- **Aplicación cliente** : autenticación moderna o protocolos heredados
- **Riesgo de inicio de sesión** : evaluación de riesgos en tiempo real de Identity Protection
- **Riesgo del usuario:** agregar el nivel de riesgo en función del comportamiento pasado

En función de la evaluación de señales, las directivas pueden aplicar controles:

- **Bloquear el acceso** : denegar la solicitud por completo
- **Concesión de acceso con condiciones** : requerir MFA, dispositivo compatible, aplicación aprobada o cambio de contraseña
- **Controles de sesión** : limitar la duración de la sesión, aplicar restricciones aplicadas a la aplicación o usar el control de aplicaciones de acceso condicional

La **autenticación basada en tokens tradicional** concede acceso a la duración del token, incluso si cambian las condiciones. CAE permite el cumplimiento casi en tiempo real cuando:

- La cuenta de usuario está deshabilitada o eliminada
- La contraseña se cambia o restablece
- MFA está habilitado para el usuario
- El administrador revoca explícitamente los tokens
- El nivel de riesgo de usuario se eleva

Tipo de riesgo	Description	Examples
Riesgo de inicio de sesión	Probabilidad de que el inicio de sesión no esté autorizado	Viajes atípicos, IP anónima, IP vinculada a malware
Riesgo del usuario	Probabilidad de que la identidad del usuario esté en peligro	Credenciales filtradas, indicadores de inteligencia sobre amenazas

Configure directivas de acceso condicional para responder a los niveles de riesgo:

- **Bajo riesgo** : permitir el acceso con controles estándar
- **Riesgo medio** : requerir MFA o comprobación adicional
- **Alto riesgo** : bloquear el acceso o requerir el cambio de contraseña y MFA

Método	Nivel de seguridad	Experiencia del usuario
Claves de paso (FIDO2)	Highest (el más alto)	Sin contraseña, resistente a la suplantación de identidad (phishing)
Windows Hello para empresas	Highest (el más alto)	Sin contraseña, enlazado al dispositivo
Microsoft Authenticator (sin contraseña)	High	Sin contraseña, basada en teléfono
Microsoft Authenticator (notificación push)	Medio-Alto	MFA, basado en teléfono
SMS/Voz	Media	Legado, solo como alternativa
Contraseña	Low	Debe combinarse con autenticación multifactor (MFA)

Confianza cero es un modelo de seguridad basado en el principio "nunca confiar, comprobar siempre". El acceso condicional es el motor de directivas principal de Microsoft Entra ID que aplica los principios de confianza cero para cada solicitud de acceso.

Principio de Confianza cero	Implementación del acceso condicional
Comprobación explícita	Evaluar todas las señales disponibles(usuario, dispositivo, ubicación, aplicación, riesgo) antes de conceder acceso
Uso del acceso con privilegios mínimos	Conceder solo acceso necesario con controles de sesión y permisos limitados por tiempo
Asunción de que hay brechas	Minimizar el radio de explosión a través de la segmentación, la comprobación continua y la detección de riesgos en tiempo real

Use esta lista de comprobación para validar la configuración del acceso condicional en función de los requisitos de confianza cero:

Controles de identidad

 MFA necesaria para todos los usuarios
 Autenticación obsoleta bloqueada
 Políticas basadas en riesgos habilitadas
 Autenticación resistente a la suplantación de identidad para cuentas con privilegios

Controles de dispositivo

 Cumplimiento de dispositivos requerido para el acceso a recursos corporativos
 Filtros de dispositivo configurados para la segmentación adecuada
 Acceso a dispositivos no administrados restringidos adecuadamente

Controles de red

 Ubicaciones con nombre definidas para redes de confianza
 Restricciones geográficas aplicadas
 Controles mejorados para el acceso a la red externa

Controles de aplicación

 Control de aplicaciones de acceso condicional habilitado para aplicaciones confidenciales
 Controles de sesión configurados correctamente
 Políticas específicas de aplicaciones para objetivos de alto valor

Supervisión y respuesta

 CAE habilitado donde sea compatible
 Directivas de riesgo de Protección de Identidad activas
 Registros de inicio de sesión supervisados
 Alertas configuradas para excepciones de directiva

Active Directory es un destino principal para los atacantes porque controla el acceso a los recursos de la organización. Entre los patrones de ataque comunes se incluyen:

Categoría de ataque	Description
Robo de credenciales	Extracción de hash de contraseñas, tickets de Kerberos o credenciales almacenadas en caché de sistemas unidos a un dominio
Escalación de privilegios	Aprovechar las configuraciones incorrectas para obtener privilegios mayores (DCSync, manipulación de AdminSDHolder)
Desplazamiento lateral	Uso de credenciales robadas para acceder a sistemas adicionales
Persistencia	Creación de puertas traseras a través de cambios de pertenencia a grupos, cuentas de servicio u Objetos de Directiva de Grupo

Microsoft recomienda un modelo administrativo en capas:

Nivel	Activos	Ámbito administrativo
Nivel 0	Controladores de dominio, PKI, AD FS	Control total de la infraestructura de identidad
Nivel 1	Servidores miembros, aplicaciones	Control de aplicaciones empresariales y datos
Nivel 2	Estaciones de trabajo, dispositivos	Control de los puntos de conexión de usuario

Azure Key Vault proporciona administración centralizada para secretos, claves y certificados. Seleccione el nivel adecuado en función de los requisitos de seguridad:

Nivel	Protección de claves	Caso de uso
Standard	Claves protegidas con software	Administración de claves y secretos de uso general
Premium	Claves protegidas por HSM (FIPS 140-2 nivel 2)	Requisitos de cumplimiento, protección mejorada de claves
HSM administrado	HSM de un solo cliente (FIPS 140-2 nivel 3)	Requisitos de seguridad más altos, cumplimiento normativo, control HSM completo

Azure Key Vault admite dos modelos de permisos:

Modelo	Recomendación	Granularidad
Azure RBAC	Recommended	Por secreto, por clave, por certificado
Directivas de acceso del almacén	Legacy	Solo a nivel de bóveda

El modelo de seguridad de Confianza cero proporciona la base para las estrategias modernas de acceso con privilegios. Al diseñar soluciones de acceso con privilegios, aplique estos principios básicos:

- **Comprobar explícitamente**: autentique y autorice siempre en función de todos los puntos de datos disponibles, incluida la identidad del usuario, la ubicación, el estado del dispositivo, el servicio o la carga de trabajo, la clasificación de datos y las anomalías.
- **Uso del acceso con privilegios mínimos**: limite el acceso de usuario con Just-In-Time (JIT) y Just-enough-access (JEA), directivas adaptables basadas en riesgos y protección de datos.
- **Asumir que hay brechas**: minimice el radio de expansión y el acceso a los segmentos. Compruebe el cifrado de un extremo a otro y use análisis para obtener visibilidad, impulsar la detección de amenazas y mejorar las defensas.

Privileged Identity Management (PIM) aborda directamente el principio de minimizar los privilegios permanentes. En lugar de conceder acceso administrativo permanente, PIM le permite administrar, controlar y supervisar el acceso a recursos críticos en microsoft Entra ID, Azure y Microsoft 365.

Azure Lighthouse aborda los desafíos de administración multiinquilino al habilitar el acceso seguro y delegado a los recursos de Azure del cliente desde un inquilino de administración.

Consideración de diseño	Funcionalidad de Azure Lighthouse
Separación de límites administrativos	La administración delegada de recursos mantiene los recursos del cliente en el inquilino del mismo cliente, mientras otorga un acceso restringido para la gestión de usuarios del inquilino.
Acceso entre clientes	La gestión de acceso de usuarios de inquilinos a los recursos del cliente sin necesidad de cambiar directorios ni usar credenciales diferentes
Privilegio mínimo	Los clientes controlan exactamente qué suscripciones, grupos de recursos y roles están delegados
Visibilidad y supervisión	Los registros de actividad permanecen en los inquilinos del cliente; los inquilinos administradores pueden ver la actividad entre inquilinos en "Mis clientes".

Un **inquilino de Microsoft 365** representa una instancia dedicada de los servicios de Microsoft 365 vinculados a un inquilino de Microsoft Entra.

Proteger el acceso administrativo requiere atención tanto a las cargas de trabajo de Microsoft 365 como a la infraestructura de identidad subyacente.

Consideración de diseño	Funcionalidad de Microsoft 365
Separación de límites administrativos	Roles de administrador independientes para Exchange, SharePoint, Teams y funciones de seguridad; unidades administrativas para gestión delimitada
Acceso justo a tiempo	Microsoft Entra PIM para roles de directorio; Administración de acceso con privilegios de Microsoft Purview para JIT de nivel de tarea
Privilegio mínimo	Roles integrados detallados; roles personalizados para funciones administrativas específicas
Visibilidad y supervisión	Registro de auditoría unificado; XDR de Microsoft Defender para la supervisión de actividades administrativas

La protección del acceso con privilegios a los inquilinos de Microsoft 365 requiere:

- **Autenticación segura**: requerir MFA resistente a la suplantación de identidad (FIDO2, Windows Hello) para todo el acceso administrativo
- **Acceso condicional**: Hacer cumplir la conformidad de dispositivos, ubicaciones de confianza y políticas basadas en riesgos para inicios de sesión de administrador.
- **Separación de roles**: use cuentas de administrador dedicadas separadas de las cuentas de productividad diarias.
- **Acceso de emergencia**: mantener cuentas de emergencia con la supervisión y los controles adecuados

Una **estación de trabajo de acceso con privilegios (PAW)** es una estación de trabajo protegida configurada específicamente para tareas administrativas

confidenciales. Las PAW protegen las cuentas de alto valor proporcionando un dispositivo de confianza aislado de vectores de ataque comunes.

Control de seguridad	Enterprise	Especializada	Con privilegios
Administrado por Intune	Sí	Sí	Sí
Denegar registro BYOD	No	Sí	Sí
Línea base de seguridad aplicada	Sí	Sí	Sí
Microsoft Defender para punto de conexión	Sí	Sí	Sí
Derechos de administrador local quitados	No	Sí	Sí
Control de aplicaciones (AppLocker/WDAC)	No	Auditoría	Aplicado
Aplicaciones instaladas solo por TI	No	Sí	Sí
Exploración web restringida	Permitir la mayoría	Permitir la mayoría de las opciones	Denegar configuración predeterminada

Azure Bastion proporciona conectividad RDP segura y SSH a máquinas virtuales de Azure sin exponer direcciones IP públicas.

Ataques de robo de credenciales

- **Pass-the-hash (PtH):** los atacantes extraen los hash de contraseña de la memoria y los usan para autenticarse sin conocer la contraseña real.
- **Pass-the-ticket (PtT):**los atacantes roban vales de Kerberos y los usan para suplantar a los usuarios.
- **Kerberoasting**: los atacantes solicitan tickets de servicio para cuentas con nombres de entidad de seguridad de servicio (SPN) y luego los descifran fuera de línea para obtener las contraseñas de las cuentas de servicio.
- **DCSync**: los atacantes con privilegios suficientes replican hashes de contraseña directamente desde controladores de dominio

Ataques de escalación de privilegios

- **Golden ticket**: los atacantes crean tickets Kerberos falsificados mediante el hash de cuenta KRBTGT, concediéndoles acceso ilimitado a dominios
- **Silver ticket**: los atacantes falsifican tickets de servicio utilizando hashes de cuentas de servicio

- **Abuso de AdminSDHolder**: los atacantes modifican el objeto AdminSDHolder para concederse acceso con privilegios persistentes.

Movimiento lateral

- **Abuso de delegación sin restricciones**: los atacantes aprovechan los servidores con delegación sin restricciones para capturar credenciales
- **Abuso de relación** de confianza: los atacantes aprovechan las relaciones de confianza entre dominios o bosques para moverse lateralmente

El **Enterprise Access Model (EAM)** define una arquitectura para segmentar y proteger accesos en:

- **Plano de control** (identidad, gobierno, políticas)
- **Plano de administración** (operaciones y gestión)
- **Plano de cargas de trabajo y datos**

El objetivo principal de una función de **operaciones de seguridad en la nube** (**SecOps**) es detectar, responder y recuperarse de ataques activos en recursos empresariales. A medida que SecOps madura, las operaciones de seguridad deben cumplir estos requisitos:

- Responder de forma reactiva a los ataques detectados por las herramientas
- Buscar de forma proactiva ataques que han superado detecciones reactivas anteriores

Los equipos de operaciones de seguridad suelen centrarse en tres resultados clave:

- **Administración de incidentes:** administre ataques activos en el entorno, incluido:
    - **Respuesta reactiva** a los ataques detectados.
    - **Búsqueda proactiva** de ataques que se han desenlazado a través de las detecciones de amenazas tradicionales.
    - **Coordinación** de las implicaciones legales, de comunicaciones y otras implicaciones empresariales de los incidentes de seguridad.
- **Preparación de incidentes:** ayude a la organización a prepararse para futuros ataques. La preparación de incidentes es un conjunto estratégico más amplio de actividades que están destinadas a crear memoria y contexto en todos los niveles de la organización. Esta estrategia prepara

a las personas para controlar mejor los ataques importantes y obtener información sobre las mejoras de procesos de seguridad.

- **Inteligencia sobre amenazas:** recopilación, procesamiento y difusión de la inteligencia sobre amenazas para las operaciones de seguridad, los equipos de seguridad, la dirección de seguridad y las partes interesadas de la dirección empresarial a través de la dirección de seguridad.

La supervisión se centra en la visibilidad en tiempo real de las amenazas de estado, rendimiento y seguridad del sistema. Responde a la pregunta "¿Qué está sucediendo ahora?" y habilita la detección y respuesta inmediatas. **El registro** se centra en la grabación de eventos para análisis, cumplimiento y análisis forenses posteriores, respondiendo "¿Qué ha ocurrido?".

Azure Arc amplía la plataforma Azure para administrar y controlar la infraestructura en entornos locales, multinube y perimetrales:

- **Administración unificada de recursos** mediante la proyección de recursos que no son de Azure en Azure Resource Manager
- **Aplicación coherente de directivas** mediante Azure Policy en Azure, instancias locales, AWS EC2 e instancias de máquina virtual de GCP
- **Supervisión centralizada** a través de Azure Monitor para todos los recursos conectados independientemente de la ubicación
- **Inventario y visibilidad** con un inventario basado en la nube que reúne azure e infraestructura híbrida

Azure Monitor proporciona una supervisión completa de los recursos en entornos locales y en la nube. Aunque Azure Monitor admite la supervisión en tiempo real y la recopilación de registros, esta sección se centra en las funcionalidades de supervisión.

Capacidad	Description
Metrics	Recopila y analiza datos numéricos de rendimiento de fuentes de Azure, locales y multinube para visibilidad en tiempo real.
VM Insights	Supervisión del rendimiento del sistema operativo y detección de componentes de aplicación en máquinas híbridas
Container Insights	Uso de Kubernetes habilitado por Azure Arc para la supervisión coherente de clústeres en AKS, AWS EKS y GCP GKE.
Paneles y libros de trabajo	Visualización de métricas de rendimiento en tiempo real y creación de informes interactivos para la visibilidad operativa

El agente de Azure Monitor se puede implementar en máquinas virtuales de Azure y servidores habilitados para Azure Arc mediante las mismas reglas de recopilación de datos en todos los entornos.

Las reglas de recopilación de datos (DCR) definen qué telemetría recopilar y dónde enviarlos, lo que permite una supervisión coherente en entornos híbridos y multinube.

Azure Monitor proporciona funcionalidades de alerta que funcionan de forma coherente en entornos híbridos:

Tipo de alerta	Caso de uso
Alertas de métricas	Alertas casi en tiempo real que comparan los valores recopilados con umbrales estáticos o dinámicos mediante el aprendizaje automático
Alertas de búsqueda de registros	Identificar problemas mediante el análisis de datos de registro en varios servidores mediante consultas KQL
Alertas de registros de actividad	Supervisión de las operaciones de recursos de Azure y los eventos de estado del servicio

El registro se centra en la grabación de eventos para el análisis histórico, la evidencia de cumplimiento y las investigaciones forenses. Responde a las preguntas "¿Qué ha ocurrido?" y "¿Podemos demostrar el cumplimiento?" **La auditoría** realiza un seguimiento específico de las actividades de usuario y administrador para establecer la responsabilidad y cumplir los requisitos normativos.

Dominio	Lo que cubre	Herramientas principales	Características de la bitácora
Infraestructura	Máquinas virtuales, contenedores, redes, bases de datos, recursos en la nube, servicios de IA	Azure Monitor, Defender for Cloud, registros de actividad de Azure	Colección basada en agentes, centrada en recursos y alto volumen
Productividad	Correo electrónico, archivos, identidad, colaboración, actividades de Copilot	Auditoría de Microsoft Purview, Defender XDR, registros de Entra ID	Recopilación basada en servicios, centrada en el usuario, crítica para el cumplimiento

Ambos dominios son esenciales para las operaciones de seguridad completas:

- **Los registros de infraestructura** le ayudan a detectar ataques en cargas de trabajo, investigar el movimiento lateral y comprender las amenazas de nivel de recurso.
- **Los registros de productividad** le ayudan a detectar cuentas en peligro, a investigar la filtración de datos y a establecer la responsabilidad del usuario.

Las áreas de trabajo de Log Analytics sirven como repositorio central para los datos de registro en la arquitectura de seguridad de Microsoft. Tanto Azure Monitor como Microsoft Sentinel almacenan sus datos en áreas de trabajo de

Log Analytics: **Microsoft Sentinel** es básicamente una solución de seguridad que se ejecuta sobre un área de trabajo de Log Analytics.

La configuración de diagnóstico es el mecanismo de configuración para recopilar registros de recursos de Azure.

Microsoft Sentinel proporciona dos niveles de almacenamiento optimizados para diferentes casos de uso:

Nivel	Propósito	Retention	Más adecuado para
Nivel de análisis	Consultas de alto rendimiento para análisis, alertas, búsqueda y todas las características de Microsoft Sentinel en tiempo real	Valor predeterminado de 30 días; Las tablas de soluciones de Microsoft Sentinel se extienden a 90 días gratis; puede extender hasta dos años a costo	Datos de seguridad principales que requieren detección e investigación en tiempo real
Nivel de Data Lake	Almacenamiento a largo plazo rentable con análisis programados	Hasta 12 años	Datos de seguridad secundarios, retención de cumplimiento, análisis histórico de tendencias

El lago de datos(Data Lake) de Microsoft Sentinel es un lago de datos nativo de nube totalmente administrado diseñado para las operaciones de seguridad.

Microsoft Purview Audit proporciona una solución de auditoría integrada para los servicios de Microsoft 365, realizando un seguimiento continuo de las actividades de usuarios y administradores para respaldar investigaciones de seguridad, análisis forenses y cumplir con las obligaciones de cumplimiento.

Nivel	Retención predeterminada	Retención extendida	Consideración de diseño
Auditoría (Estándar)	180 días	N/A	Incluido con la mayoría de las licencias de Microsoft 365; suficiente para la auditoría general
Auditoría (Premium)	Un año para Exchange, SharePoint, Id. de Entra	Hasta 10 años con licencia adicional	Requerido para el cumplimiento normativo; incluye eventos forenses de alto valor (MailItemsAccessed, SearchQueryInitiated)

La detección y respuesta extendidas (XDR) y la **información de seguridad y la administración de eventos (SIEM)** son soluciones complementarias que proporcionan funcionalidades completas de detección y respuesta de amenazas.

XDR es una plataforma unificada de incidentes de seguridad que usa inteligencia artificial y automatización para proporcionar a las organizaciones una manera holística de protegerse y responder a ataques cibernéticos avanzados. Las plataformas XDR integran las funcionalidades de detección, investigación y respuesta en puntos de conexión, identidades, aplicaciones en la nube, correo electrónico y tecnología operativa.

Las soluciones **SIEM** recopilan, agregan, normalizan y analizan grandes volúmenes de datos de aplicaciones, dispositivos, servidores y usuarios de toda la organización casi en tiempo real. Al consolidar la telemetría en una plataforma unificada, las soluciones SIEM proporcionan una visión completa de la posición de seguridad de una organización.

Microsoft Sentinel es una plataforma de seguridad unificada y SIEM nativa de la nube para la defensa proactiva. Ha evolucionado más allá del tradicional SIEM para proporcionar una base preparada para la inteligencia artificial y centrada en los datos que transforma la telemetría en un gráfico de seguridad; estandariza el acceso para los agentes de inteligencia artificial y coordina las acciones autónomas, mientras mantiene a los humanos al mando de la estrategia y las investigaciones de alto impacto.

- **Recopilación completa de datos** entre usuarios, dispositivos, identidades, aplicaciones, infraestructura y tecnología operativa a través de más de 350 conectores
- **Detección avanzada de amenazas** con reglas de análisis integradas, modelos de aprendizaje automático y enriquecimiento con inteligencia sobre amenazas
- **Herramientas de eficiencia de SOC**, incluidos incidentes unificados, páginas de entidades, gráfico de investigación, cuadernos de búsqueda e integración de Seguridad de Copilot.

La arquitectura de datos en capas de Microsoft Sentinel admite la detección en tiempo real y la investigación a largo plazo:

- **Nivel de análisis** : almacenamiento de alto rendimiento para la detección, alertas e investigación interactiva en tiempo real
- **Nivel de Data Lake**: almacenamiento rentable para el análisis histórico, los estándares de comportamiento y la retención para cumplimiento
- **Creación de reflejo automática** : los datos ingeridos en el nivel de análisis se reflejan automáticamente en el nivel de lago de datos, lo que garantiza un repositorio unificado.

El portal de Microsoft Defender proporciona operaciones de seguridad unificadas que integran:

- Administración de eventos e información de seguridad (SIEM)
- Orquestación de seguridad, automatización y respuesta (SOAR)
- Detección y respuesta extendida (XDR)
- Administración de la posición y la exposición

- Seguridad en la nube, inteligencia sobre amenazas e inteligencia artificial generativa

MITRE ATT&CK es una base de conocimiento accesible públicamente de tácticas y técnicas que suelen usar los atacantes. Creadas y mantenidas a través de observaciones reales, muchas organizaciones usan MITRE ATT&CK para desarrollar modelos de amenazas y metodologías para comprobar el estado de seguridad en sus entornos.

La puntuación de seguridad de Microsoft es una medida numérica de la posición de seguridad de su organización, disponible en el portal de Microsoft Defender. Una puntuación más alta indica que se implementan acciones de seguridad más recomendadas. La puntuación de seguridad ayuda a su organización:

- **Informe** sobre el estado actual de la posición de seguridad en las cargas de trabajo de productividad.
- **Mejore la** posición al proporcionar detectabilidad, visibilidad, orientación y control.
- **Realizar pruebas comparativas** con organizaciones similares y establecer indicadores clave de rendimiento (KPI).

Las acciones recomendadas se organizan en **cuatro** grupos que se alinean con las dimensiones principales de la seguridad de la carga de trabajo de productividad:

- **Identidad**: cuentas y roles de Microsoft Entra, incluida la autenticación multifactor, las directivas de acceso condicional y la administración de roles con privilegios.
- **Dispositivo**: recomendaciones de Microsoft Defender para punto de conexión, que se tratan en Puntuación de seguridad de Microsoft para dispositivos, incluida la administración de vulnerabilidades y la configuración del punto de conexión.

- **Aplicaciones**: seguridad de aplicaciones en la nube y correo electrónico, incluidas las directivas de protección de Exchange Online y las configuraciones de Defender for Cloud Apps.
- **Datos**: recomendaciones de Microsoft Purview Information Protection, que incluyen la clasificación de datos, las etiquetas de confidencialidad y las directivas de prevención de pérdida de datos.

La administración de exposición de seguridad de Microsoft se basa en la puntuación de seguridad al proporcionar una vista unificada de la posición de seguridad en todo el patrimonio digital, incluidos los puntos de conexión, los recursos en la nube y las superficies de ataque externas.

Administración de vulnerabilidades de Microsoft Defender ahora reside en Gestión de Exposición de Seguridad, proporcionando una experiencia unificada de administración de vulnerabilidades en todo el entorno digital.

Microsoft Defender para Office 365 protege a su organización frente a amenazas sofisticadas en herramientas de correo electrónico y colaboración, como phishing, malware de día cero y peligro de correo electrónico empresarial (BEC).

Microsoft Defender for Cloud Apps es un agente de seguridad de acceso a la nube (CASB) que ofrece protección completa para las aplicaciones SaaS. Proporciona visibilidad sobre el uso de aplicaciones en la nube, aplica controles de acceso en tiempo real y protege los datos confidenciales almacenados en los servicios en la nube.

Defender for Cloud Apps aborda cuatro áreas clave:

- **Detección de SHADOW IT**: identifica las aplicaciones en la nube que se usan en toda la organización mediante el análisis del tráfico de red en un amplio catálogo de aplicaciones de más de 31 000 aplicaciones. Cada aplicación recibe una puntuación de riesgo basada en más de 90 indicadores de riesgo, que incluyen factores de seguridad, cumplimiento y legales. Esta evaluación le ayuda a determinar qué aplicaciones autorizar, supervisar o bloquear.
- **Administración de posiciones de seguridad de SaaS (SSPM)**: expone configuraciones incorrectas en aplicaciones SaaS conectadas y recomienda acciones específicas para reforzar su posición de seguridad. Las fuentes de datos de SSPM alimentan directamente el puntaje de seguridad de Microsoft, proporcionando una visión conjunta de la

postura de seguridad en aplicaciones de Microsoft y aplicaciones conectadas que no son de Microsoft.

- **Protección de la información**: se integra con Microsoft Purview para examinar archivos en aplicaciones SaaS conectadas para datos confidenciales. Puede aplicar controles como etiquetas de confidencialidad, bloques de descarga en dispositivos no administrados y eliminación de colaboradores externos en archivos confidenciales.
- **Protección de aplicación a aplicación con gobernanza de aplicaciones**: supervisa y rige las aplicaciones habilitadas con OAuth que tienen permisos para acceder a los datos en otras aplicaciones por parte de los usuarios. Realiza un seguimiento de las aplicaciones no usadas, supervisa las credenciales actuales y expiradas y ayuda a mantener la higiene de las aplicaciones en toda la organización.

El control de aplicaciones de acceso condicional usa una arquitectura de proxy inverso integrada con el acceso condicional de Microsoft Entra para supervisar y controlar las sesiones de usuario en tiempo real.

Microsoft Intune proporciona dos enfoques de administración principales que puede usar de forma independiente o conjunta, en función de los requisitos de su organización.

MDM le proporciona control total sobre los dispositivos inscritos. MDM de Intune admite varias plataformas, como Windows, macOS, iOS/iPadOS, Android y Linux.

MAM protege los datos de la organización en el nivel de aplicación sin necesidad de inscripción completa de dispositivos.

Intune organiza las directivas de protección de aplicaciones en tres niveles que se alinean con el aumento de los requisitos de seguridad:

- **Nivel 1 (Enterprise basic):** protección de datos mínima recomendada para todos los dispositivos empresariales.
- **Nivel 2 (mejorado para empresas):** recomendado para dispositivos que acceden a información confidencial o confidencial. Algunos controles pueden afectar a la experiencia del usuario.
- **Nivel 3 (Alta empresa):** recomendado para dispositivos usados por usuarios de alto riesgo o en entornos con datos altamente confidenciales, donde la divulgación no autorizada provoca pérdida de material.

Microsoft Purview proporciona un conjunto unificado de soluciones de seguridad de datos que le ayudan a detectar, clasificar, proteger y controlar información confidencial en Microsoft 365.

Los tipos de información confidencial (SIT) usan la coincidencia de patrones para identificar datos confidenciales. Los SIT integrados cubren patrones comunes, como números de tarjeta de crédito, números de seguridad social y números de pasaporte en más de 300 tipos. También puede crear SIT personalizados mediante expresiones regulares, palabras clave y niveles de confianza. Para obtener la mayor precisión, los SIT de coincidencia exacta de datos (EDM) comparan el contenido con los valores hash de los datos reales (como registros de empleados o bases de datos de pacientes) para eliminar falsos positivos.

Los clasificadores entrenables usan aprendizaje automático para identificar categorías de contenido que la coincidencia de patrones no puede detectar fácilmente, como contratos, currículums, estados financieros o código fuente. Microsoft proporciona clasificadores entrenados previamente para tipos de contenido comunes y puede entrenar clasificadores personalizados con ejemplos de sus propios datos.

El **panel de clasificación de datos** del portal de Microsoft Purview proporciona visibilidad sobre el panorama de datos de la organización. El Explorador de contenido muestra qué elementos contienen tipos de información confidencial específicos o tienen aplicadas etiquetas de confidencialidad. El Explorador de actividades realiza un seguimiento de las acciones de usuario en contenido clasificado, incluidos los cambios de etiqueta, el acceso a archivos y los eventos de uso compartido. Estas conclusiones le ayudan a evaluar la cobertura de clasificación e identificar brechas en las directivas de protección.

Las etiquetas de confidencialidad son el mecanismo de protección fundamental en Microsoft Purview. Cada etiqueta representa un nivel de confidencialidad (como Público, General, Confidencial o Extremadamente Confidencial) y puede aplicar acciones de protección automáticamente cuando se aplican.

Un marcador de sensibilidad puede asignar cualquier combinación de:

- **Cifrado** que restringe quién puede acceder al contenido y qué derechos de uso tienen (ver, editar, copiar, imprimir, reenviar).
- **Marcas de contenido** como encabezados, pies de página y marcas de agua que proporcionan indicadores visuales de sensibilidad.
- **Restricciones de acceso** que impiden acciones específicas, como reenviar correos electrónicos o copiar contenido.

El cifrado de clave doble (DKE) usa dos claves para proteger los datos: una clave que su organización controla de forma local y una segunda clave almacenada en Azure. Ambas claves son necesarias para descifrar el

contenido. Dado que Microsoft nunca tiene acceso a la clave, ningún servicio de Microsoft 365 puede procesar el contenido protegido por DKE, incluidas las características de búsqueda, eDiscovery e AI. Use DKE solo para el contenido más restringido en el que esta compensación sea aceptable.

Clave de cliente proporciona control sobre las claves de cifrado raíz que Microsoft 365 usa para cifrar los datos en reposo en Exchange Online, SharePoint, OneDrive y Teams. A diferencia de DKE, la clave de cliente todavía permite a los servicios de Microsoft 365 procesar contenido cifrado. La clave de cliente aborda los requisitos normativos que exigen el control sobre las claves de cifrado sin sacrificar la funcionalidad del servicio.

Microsoft Defender for Cloud es una plataforma de protección de aplicaciones nativas en la nube (CNAPP) que unifica tres funcionalidades principales en una única solución:

- **Cloud Security Posture Management (CSPM)** comprueba y mejora la posición de seguridad entre los recursos en la nube.
- **Las operaciones de seguridad de desarrollo (DevSecOps)** gestionan la seguridad a nivel de código en entornos de nube múltiple y multiproceso.
- **Cloud Workload Protection Platform (CWPP)** defiende cargas de trabajo como máquinas virtuales, contenedores, bases de datos y funciones sin servidor frente a amenazas.

El modelado de amenazas es una técnica de análisis estructurado que identifica posibles amenazas de seguridad durante la fase de diseño, antes de escribir el código. Responde a cuatro preguntas clave:

1. **¿Qué estás construyendo?** Defina la arquitectura del sistema, los flujos de datos, los límites de confianza y las dependencias externas.
2. **¿Qué puede ir mal?** Identifique sistemáticamente posibles amenazas mediante una metodología probada.
3. **¿Qué vas a hacer sobre eso?** Defina mitigaciones para cada amenaza identificada, priorizada por riesgo.
4. **¿Hiciste un buen trabajo?** Compruebe que las mitigaciones son eficaces y no se han perdido amenazas significativas.

Una identidad de carga de trabajo es una identidad asignada a una carga de trabajo de software, como una aplicación, servicio, script o contenedor, que le

permite autenticar y acceder a otros servicios y recursos. En microsoft Entra ID, las identidades de carga de trabajo tienen tres formas:

- **Las aplicaciones** son entidades abstractas definidas por objetos de aplicación. El objeto de aplicación es la representación global que describe cómo se emiten los tokens, qué recursos necesita la aplicación y qué acciones puede realizar la aplicación.
- **Las entidades de servicio** son la representación local (instancia) de una aplicación en un inquilino específico. Definen lo que la aplicación puede hacer realmente en ese inquilino, quién puede usarla y a qué recursos puede acceder.
- **Las identidades administradas** son un tipo especial de entidad de servicio que elimina la necesidad de que los desarrolladores administren las credenciales. Azure administra automáticamente el ciclo de vida de la identidad y la rotación de credenciales.

Azure API Management (APIM) proporciona una puerta de enlace de API unificada, un plano de administración y un portal para desarrolladores que se encuentra entre los consumidores de API y los servicios de back-end. Actúa como punto de cumplimiento de directivas en el que se aplican controles de seguridad de forma coherente en todas las API, independientemente de dónde se hospeden los back-end.

Los componentes clave son:

- **Puerta de enlace de API:** el punto de conexión que acepta llamadas API y las enruta a los sistemas de back-end. Aplica directivas para la autenticación, limitación de velocidad, transformación y registro.
- **Plano de administración:** la interfaz administrativa para importar API, definir directivas y administrar usuarios y suscripciones.
- **Portal para desarrolladores:** un sitio web personalizable donde los consumidores de API detectan y prueban las API, obtienen claves de API y ven la documentación.

Azure WAF proporciona protección centralizada y nativa de la nube para aplicaciones web frente a exploits y vulnerabilidades comunes. Inspecciona el tráfico HTTP/HTTPS entrante en un conjunto de reglas y puede bloquear, registrar o redirigir solicitudes malintencionadas antes de llegar a la aplicación. Un WAF centralizado simplifica la administración de seguridad porque aplica revisiones a vulnerabilidades conocidas en un solo lugar en lugar de proteger individualmente cada aplicación web.

Azure WAF se puede implementar con los siguientes servicios:

- **Azure Application Gateway:** un equilibrador de carga de nivel 7 para el tráfico regional.
- **Azure Front Door:** un servicio de aceleración de aplicaciones y entrega de contenido global.
- **Azure Application Gateway for Containers:** una puerta de enlace de aplicaciones que administra el tráfico a cargas de trabajo en contenedores.
- **Azure Content Delivery Network (CDN):** Red de Distribución de Contenidos de Azure.

Azure Application Gateway es un equilibrador de carga de nivel 7 regional. Al habilitar WAF en Application Gateway, inspecciona todas las solicitudes HTTP/HTTPS entrantes para protegerse frente a ataques de aplicaciones web.

Azure Front Door es un servicio global que acelera la entrega de aplicaciones y proporciona equilibrio de carga global. WAF en Front Door inspecciona el tráfico en las ubicaciones perimetrales de Azure antes de llegar a los servidores de origen, lo que reduce la latencia de las decisiones de bloqueo y protege frente a ataques distribuidos geográficamente.

El diseño de seguridad de datos efectivo sigue los principios de confianza cero: compruebe explícitamente, use el acceso con privilegios mínimos y asuma la vulneración. Estos principios se traducen en consideraciones arquitectónicas específicas:

- **Conoce tus datos**: no puedes proteger lo que no sabes que existe. La detección y la clasificación forman la base de cualquier estrategia de seguridad de datos.
- **Proteger los datos en su ciclo de vida**: los datos requieren protección en reposo, en tránsito y en uso. Cada estado presenta riesgos únicos y requiere controles específicos.
- **Implementar defensa en profundidad**: capa de varios controles de seguridad para que, si se produce un error, otros siguen proporcionando protección.
- **Automatizar la protección siempre que sea posible**: los procesos manuales no son escalables. Use la automatización para aplicar de forma coherente las directivas en el patrimonio de datos.

La taxonomía de clasificación es una representación jerárquica de la categorización de datos. No hay un estándar universal para la clasificación, sino que se basa en la motivación de su organización para proteger los datos. La taxonomía puede capturar los requisitos de cumplimiento, las características

prometidas para los usuarios de cargas de trabajo u otros criterios controlados por las necesidades empresariales.

El cifrado de infraestructura proporciona una segunda capa de cifrado para datos altamente confidenciales:

- **Primera capa**: cifrado de nivel de servicio con claves administradas por el servicio o administradas por el cliente
- **Segunda capa**: cifrado de nivel de infraestructura con claves administradas por Microsoft

La línea base de **PaaS** debe requerir lo siguiente:

- **Acceso condicional de Microsoft Entra** para cargas de trabajo administrativas y confidenciales
- **Autenticación multifactor** para todos los usuarios, con métodos resistentes a la suplantación de identidad (phishing), como claves de acceso o FIDO2 para roles con privilegios
- **Privileged Identity Management (PIM)** para eliminar privilegios permanentes para el acceso administrativo
- **Identidades administradas** para la autenticación de aplicaciones para evitar el almacenamiento de credenciales en el código

La línea base de **SaaS** debe abordar:

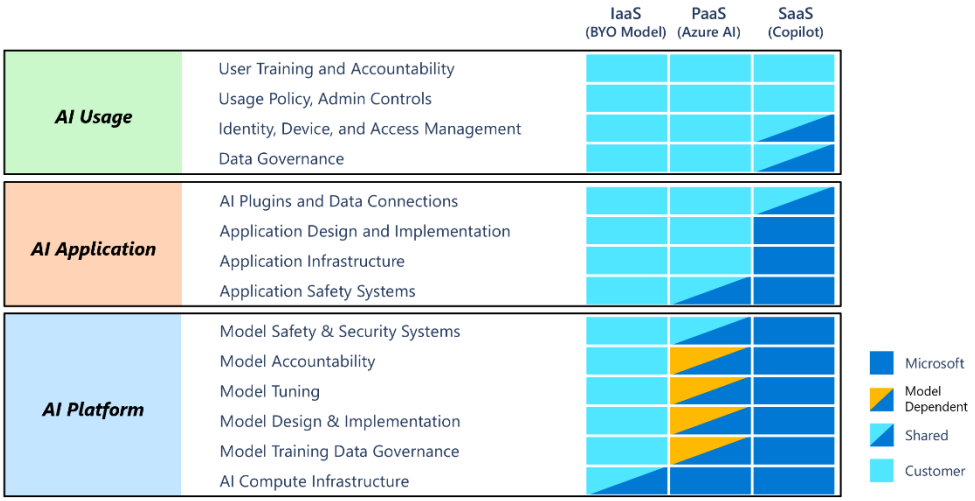
- **Detección y evaluación** de aplicaciones: inventario de aplicaciones SaaS y evaluación de su posición de seguridad
- **Gobernanza de acceso**: implementación de directivas de acceso condicional que controlan cómo los usuarios acceden a las aplicaciones SaaS
- **Protección de datos**: aplicar etiquetas de confidencialidad y directivas de prevención de pérdida de datos para evitar el uso compartido de datos no autorizado
- **Controles de sesión**: usar controles y supervisión de sesiones en tiempo real para operaciones confidenciales

La autenticación de dispositivos es la base de la seguridad de IoT. Los requisitos de seguridad deben especificar cómo los dispositivos demuestran su identidad al conectarse a los servicios en la nube.

Requerir autenticación basada en **certificados X.509** para implementaciones de IoT de producción. Los certificados X.509 proporcionan mayor seguridad que las claves simétricas porque:

- Los certificados se pueden almacenar en módulos de seguridad de hardware (HSM) o módulos de plataforma segura (TPM), protegiendo contra la extracción.
- Las cadenas de certificados permiten modelos de confianza jerárquicos alineados con las cadenas de suministro de fabricación
- Los certificados se pueden revocar individualmente sin afectar a otros dispositivos
- Las claves privadas nunca dejan el dispositivo, lo que elimina los riesgos de transmisión de claves

AI Shared Responsibility Model



Defender for Cloud evalúa continuamente los recursos con Microsoft Cloud Security Benchmark (MCSB) y genera recomendaciones de seguridad cuando las configuraciones no cumplen los requisitos de pruebas comparativas.

La puntuación de seguridad en la nube es un cálculo basado en riesgos que agrega recomendaciones abiertas al factorizar:

- **Nivel de riesgo** de recomendación: los resultados críticos, altos, medianos y de gravedad baja se ponderan en consecuencia.
- **Factores de riesgo** de recursos: factores contextuales, como la exposición a Internet y la confidencialidad de los datos
- **Importancia** de los recursos: la importancia de cada recurso para su organización

Los requisitos de seguridad para dispositivos móviles y clientes deben abordar tres áreas fundamentales:

- **Endpoint Protection**: funcionalidades de detección y respuesta para amenazas dirigidas al dispositivo
- **Endurecimiento**: Opciones de configuración que reducen la superficie de ataque.
- **Protección de datos**: controles que impiden el acceso no autorizado y la pérdida de datos corporativos

Una línea base de seguridad es un grupo de configuraciones preconfiguradas que implementan la posición de seguridad recomendada de Microsoft. Esta configuración aborda las amenazas contemporáneas a la vez que evita problemas operativos. Los principios de línea de base siguen un enfoque simplificado:

- Las configuraciones base asumen entornos bien administrados en los que los usuarios estándar no tienen derechos administrativos
- La configuración solo se aplica cuando mitigan las amenazas actuales sin causar problemas operativos peores
- Los valores predeterminados solo se aplican cuando, en caso contrario, es probable que se establezcan de forma no segura.

Las cuentas de administrador local presentan riesgos de seguridad significativos cuando las contraseñas se comparten o reutilizan en todos los dispositivos. Windows LAPS aborda estas amenazas:

- **Ataques pass-the-hash**: cuando los atacantes capturan un hash de contraseña de administrador local de un dispositivo, pueden usarlo para autenticarse en otros dispositivos con las mismas credenciales. Windows LAPS genera contraseñas únicas para cada dispositivo.
- **Recorrido lateral**: los atacantes que ponen en peligro un dispositivo a menudo intentan moverse lateralmente a través de la red. Las contraseñas de administrador local únicas limitan este movimiento.

- **Persistencia de credenciales**: las contraseñas de administrador local estáticas permanecen válidas indefinidamente a menos que se cambien manualmente. Windows LAPS gira automáticamente las contraseñas en función de la directiva.

Confianza cero es el marco fundamental para evaluar los diseños de seguridad de red modernos. Las redes tradicionales basadas en perímetro asumen que todos los sistemas dentro del límite pueden ser de confianza. Esta suposición produce un error cuando los empleados acceden a los recursos desde cualquier lugar y los atacantes que infringen el perímetro pueden moverse lateralmente a través de la red.

Al evaluar un diseño de red, evalúe si aplica estos tres principios de confianza cero:

- **Comprobar de forma explícita.** ¿El diseño autentica y autoriza cada solicitud de acceso en función de todas las señales disponibles, incluida la identidad del usuario, el estado del dispositivo, la ubicación y el contexto de carga de trabajo?
- **Use el acceso con privilegios mínimos.** ¿El diseño limita el acceso solo a los recursos necesarios, utilizando enfoques just-in-time y de acceso suficiente?
- **Supongamos la vulneración.** ¿El diseño minimiza el radio de explosión a través de la segmentación y comprueba el cifrado de un extremo a otro, con análisis de visibilidad y detección de amenazas?

La segmentación de red divide la red en segmentos más pequeños y aislados para que pueda controlar el flujo de tráfico, limitar el radio de explosión y evitar el movimiento lateral no autorizado.

La administración de la posición de red es la práctica continua de evaluar, supervisar y mejorar el estado de seguridad de la infraestructura de red.

Defender for Cloud ofrece dos niveles de CSPM, cada uno con distintos niveles de información de posición de red:

- **CSPM básico (gratis)** proporciona inventario de recursos, recomendaciones de seguridad basadas en MCSB y una puntuación segura que cuantifica su posición general. Trata las comprobaciones de red principales, como si las subredes tienen grupos de seguridad de red (NSG), si las máquinas virtuales (VM) accesibles desde Internet están protegidas y si las cuentas de almacenamiento restringen el acceso a la red.

- **CSPM de Defender (de pago)** agrega funcionalidades avanzadas, como el análisis de rutas de ataque, la priorización de riesgos, el Explorador de seguridad en la nube, la administración externa de la superficie expuesta a ataques, el análisis de exposición a Internet y las reglas de gobernanza. Estas características proporcionan información más detallada sobre cómo las configuraciones incorrectas de red crean rutas de acceso aprovechables a los recursos críticos.

Microsoft Entra Private Access es el componente Acceso de red de confianza cero (ZTNA) de la solución Microsoft Security Service Edge (SSE).

Acceso rápido es una sola aplicación empresarial que actúa como contenedor principal para todos los recursos privados que desea tunelizar a través del servicio.

El acceso por aplicación usa aplicaciones empresariales de Acceso seguro global individuales, cada una que contiene su propio conjunto de segmentos de aplicación y se asigna a su propio grupo de conectores.